

Lab 2

Vulnerability Assessment Report

Evan Bettencourt, Jeffrey Lam Ping Fong, Easton Soares,
Jacob Williams

Suranjit Paul

WAS705 NBB

27th May 2026

Table of Contents

- Executive Summary.....3**
- Third Party Library Review..... 4**
 - Critical Findings..... 4
 - High-Risk Components.....4
 - Medium-Risk Findings..... 5
 - Low-Risk and Informational Findings.....5
- Comparison with Previous Versions and Competitors..... 6**
 - Previous Version of Penpot..... 6
 - CVE-2026-26202 - Arbitrary File Read via create-font-variant RPC Endpoint..... 6
 - Competitors..... 7
 - Figma.....7
 - Canva.....7
 - Comparative Security Posture..... 7
- Results.....8**
 - Tools Used..... 8
 - Scan results..... 8
 - Nmap..... 8
 - Nikto..... 10
 - Burpsuite..... 17
 - Risk Assessment..... 18
 - Summary & Analysis..... 19
- References..... 20**

Executive Summary

This security assessment evaluated Penpot v2.15.3 across reconnaissance, vulnerability scanning, and application testing phases using industry-standard tools including Nmap, Nikto, and Burp Suite, supplemented by a Software Bill of Materials analysis. The assessment targeted a locally deployed instance at 192.168.56.102:9001 with explicit authorization from Penpot's maintainers.

Reconnaissance and service enumeration via Nmap confirmed port 9001 is open and running nginx as a reverse proxy on a modern Linux host. No unexpected services or network-layer vulnerabilities were discovered. Nikto's web application scan completed across 8,309 requests and reported 22 findings, of which 19 were confirmed as false positives caused by Penpot's single-page application architecture and nginx's catch-all routing behavior, which returns HTTP 200 with the SPA index page for unmatched routes. Three legitimate findings emerged: missing Content-Security-Policy, Strict-Transport-Security, and X-Content-Type-Options headers. These are low-severity issues appropriate for a development instance and easily remediated in production through nginx configuration.

Manual API assessment via Burp Suite revealed a well-structured REST API and functional authentication flows with no unexpected endpoints or information leakage vulnerabilities. Session management relies on JWT-based auth tokens and x-session-id headers; credentials are transmitted in plaintext HTTP during the registration flow, which is standard for localhost development but highlights the requirement for HTTPS enforcement in production deployments. WebSocket connections for real-time collaboration features use session IDs in URLs, which could expose sessions if server-side logs capture full request URLs.

Third-party component analysis via SBOM identified 3,789 npm dependencies, with vulnerability assessment focusing on critical components. While Penpot bundles React 19.2.3, which nominally falls within the version range affected by CVE-2025-55182 ("React2Shell"), this critical-severity vulnerability does not represent exploitable risk because Penpot's architecture does not use React Server Components, the framework feature required for exploitation. This case demonstrates the importance of contextual vulnerability assessment over raw CVE scoring. The primary supply chain concern is the 3,789-dependency npm footprint, which exposes Penpot to ecosystem-wide malware risks; 99.8% of Q4 2025 JavaScript malware originated from npm, and state-sponsored actors have industrialized supply chain attacks targeting developer credentials.

Compared to competitors, Figma maintains SOC 2 Type II, SOC 3, and ISO 27001:2022 certifications with a formal HackerOne bug bounty program, making it the enterprise-grade choice. Canva holds matching certifications but carries reputational risk from a 2019 data breach affecting 139 million users. Penpot lacks formal compliance certifications but differentiates through transparency and self-hosting capability, enabling organizations to achieve data sovereignty and implement custom security frameworks, a structural advantage for regulated industries.

No exploitable application-level vulnerabilities were identified in Penpot v2.15.3. Primary security concerns are operational and supply chain related: self-hosted deployments must enforce HTTPS, missing HTTP security headers should be added to production configurations, and ongoing SBOM monitoring with automated vulnerability scanning is required to detect newly disclosed transitive dependencies. The open-source model enables community security audits and independent verification of claims. Overall risk is assessed as low to moderate, contingent on implementation of operational security best practices.

Third Party Library Review

Critical Findings

React 19.2.3 and CVE-2025-55182 (React2Shell): Penpot bundles React 19.2.3, which is potentially affected by CVE-2025-55182, a CVSS 10.0 critical remote code execution vulnerability in React Server Components published on December 3, 2025. The vulnerability exists in react-server-dom-webpack, react-server-dom-parcel, and react-server-dom-turbopack packages in versions 19.0.0 through 19.2.0, with patches available in 19.0.1, 19.1.2, and 19.2.1. However, this vulnerability is not exploitable in Penpot's architecture. React Server Components are a framework feature introduced in React 19 that enable server-side code execution. Penpot's codebase analysis shows no usage of the vulnerable react-server-dom-* packages or the Flight protocol required for exploitation. Penpot is built as a client-side SPA with a separate ClojureScript backend, not using React Server Components. Therefore, CVE-2025-55182 presents zero risk to Penpot deployments despite the presence of React 19.2.3 in the codebase. This is a notable case where a critical-severity CVE does not translate to actionable vulnerability in this specific application architecture.

High-Risk Components

npm Ecosystem Supply Chain: Penpot depends on 3,789 npm packages, placing it at the center of a large attack surface. The npm ecosystem experienced unprecedented malware activity in 2025, with Sonatype reporting that 99.8% of Q4 2025 JavaScript malware originated from npm. The self-replicating Shai-Hulud worm spread across 500+ packages in September 2025 before returning in November 2025 with more sophisticated payloads targeting developer credentials. While Penpot's official repository and build pipeline are unlikely targets for direct compromise, dependency confusion attacks and transitive dependency vulnerabilities remain persistent risks. The SBOM reveals dependencies on widely-used build and testing libraries (Jest, Webpack, Rollup, Vite) that have historically been subject to supply chain attacks.

Medium-Risk Findings

TypeScript Tooling (v5.x range): Penpot includes TypeScript v5.x compiler and related tooling. While TypeScript itself has no known active CVEs affecting version 5.x, the ecosystem of TypeScript plugins, loaders, and build integrations (including webpack-dev-middleware and related tools) has experienced path traversal and arbitrary file access vulnerabilities. CVE-2024-29180 affected webpack-dev-middleware with insufficient URL validation allowing arbitrary file access on developer machines. Although this is a development-time risk rather than a production risk, it highlights the need for careful isolation of development environments from sensitive data.

Babel and Transpilation Stack: Penpot uses Babel v7.x series for transpilation and plugin transformation. The Babel ecosystem includes multiple plugins and presets (noted in the SBOM as @babel/preset-react, various transformation plugins). No critical vulnerabilities were identified in current Babel versions; however, Regular Expression Denial of Service (ReDoS) vulnerabilities have appeared in other JavaScript parsing and transformation libraries. A similar vulnerability in es5-ext (CVE-2024-27088) and micromatch (CVE-2024-4067) resulted in upstream ReDoS issues that propagate to dependent projects.

Low-Risk and Informational Findings

Storybook and Development Dependencies: Penpot includes Storybook v10.x for component documentation and testing, adding several hundred dependencies for development purposes only. Development-only dependencies generally carry lower production risk because they are not bundled or shipped with released code. However, compromise of developer machines or CI/CD pipelines through these dependencies can enable source code exfiltration or build-time injection attacks.

License Diversity and Compliance: The SBOM reveals a heterogeneous mix of open-source licenses including MIT, Apache 2.0, ISC, and others. No GPL-licensed components were detected in the critical path, reducing licensing compliance risk. However, the presence of 3,789 components implies significant license attribution and compliance documentation requirements for commercial distributions.

Comparison with Previous Versions and Competitors

Previous Version of Penpot

CVE-2026-26202 - Arbitrary File Read via create-font-variant RPC Endpoint

Severity: High (CVSS 7.5) | Published: February 16, 2026 | Advisory:
GHSA-xp3f-g8rq-9px2

An authenticated user can read arbitrary files from the server by supplying a local file path such as `/etc/passwd` as a font data chunk in the create-font-variant RPC endpoint, causing the file contents to be stored and retrievable as a font asset. [github](#)

Root cause: The create-font-variant RPC command in `backend/src/app/rpc/commands/fonts.clj` accepts a data parameter with no restrictions on value types. When font data values are provided as a vector, the process-chunks function calls `io/input-stream` on each chunk element, which interprets a bare string as a filesystem path. No path validation, allowlisting, or type checking is performed on individual chunk values before they are passed to `io/input-stream`. [github](#)

Impact: Any authenticated user with team edit permissions can read arbitrary files accessible to the Penpot backend process on the host filesystem. This can lead to exposure of sensitive system files, application secrets, database credentials, and private keys. In containerized deployments, the blast radius may be limited to the container filesystem, but environment variables, mounted secrets, and application configuration are still at risk. [github](#)

Affected versions: All versions below 2.13.2. Patched in: 2.13.2.

Competitors

Figma

The most significant publicly disclosed vulnerability in the Figma ecosystem is CVE-2025-53967, which affected the third-party Framelink Figma MCP server rather than Figma's own platform. Tracked as CVE-2025-53967 with a CVSS score of 7.5, it is a command injection flaw stemming from the unsanitized use of user input, opening the door for an attacker to send arbitrary system commands.

Canva

Canva's most significant security incident is a large-scale data breach from 2019. On May 24, 2019, hackers compromised Canva's database, stealing information tied to approximately 139 million user accounts. The stolen data included usernames, email addresses, and partially hashed passwords. The breach was linked to a hacking group known as GnosticPlayers and appeared to be part of a larger campaign targeting multiple platforms. On January 11, 2020, Canva became aware that a list of approximately 4 million accounts contained passwords that had been successfully decrypted from the stolen data and shared online, prompting Canva to invalidate unchanged passwords and notify affected users. [HuntressCanva](#)

More recently, CVE-2025-12792 (CVSS 3.2, Low) was disclosed in November 2025, affecting the Canva for Mac desktop app distributed through the Mac App Store before version 1.117.1. The app was built without Hardened Runtime, meaning a local threat actor with unprivileged access could execute arbitrary code inheriting the TCC permissions assigned to Canva. The version distributed directly through [canva.com](#) was not affected.

Comparative Security Posture

Figma presents itself as the enterprise-grade choice. Figma maintains SOC 2 Type II and SOC 3 reports showing commitment to protecting customer data through robust security, availability, and confidentiality controls aligned with AICPA Trust Services Criteria, alongside ISO/IEC 27001:2022 and ISO/IEC 27018:2019 certifications. Figma runs a formal bug bounty program through HackerOne to enlist the research community in identifying vulnerabilities. This institutional approach to security governance appeals to large organizations and heavily regulated industries.

Canva mirrors Figma's compliance certifications. Canva has attained SOC 2 Type II compliance and is ISO 27001 certified, meaning it has the people, processes, and systems in place to identify, assess, treat, and monitor information security risks. However, Canva's historical 2019 breach exposed 139 million users and created lingering trust concerns, though the platform has since rebuilt its security practices. Canva is committed to industry best practice certifications and regulatory compliance, including ISO 27001 and SOC 2 Type II certification, and has developed Canva Shield, a collection of robust trust, safety, and privacy tools for AI products.

Penpot takes a fundamentally different approach. Rather than pursuing enterprise certifications for its cloud service, Penpot positions security through transparency and flexibility. Penpot offers two distinct deployment models: a cloud service managed by Penpot's team with automatic updates, and a self-hosted option where organizations deploy Penpot entirely within their own infrastructure, achieving complete data sovereignty and customizable security controls. This is a strategic trade-off: Penpot lacks the formal audit credentials of Figma and Canva, but compensates by allowing organizations to implement their own security frameworks without vendor lock-in.

Results

Tools Used

1. Nikto
2. Nmap
3. Burpsuite

Scan results

Nmap

1. Basic service and version detection

```

(kali@kali)-[~]
$ nmap -sV -p 9001 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-28 00:44 -0400
Nmap scan report for 192.168.56.102
Host is up (0.0097s latency).

PORT      STATE SERVICE VERSION
9001/tcp  open  http    nginx
MAC Address: 08:00:27:FD:20:08 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.01 seconds

(kali@kali)-[~]
$

```

2. Aggressive scan with OS detection and traceroute

```

(kali@kali)-[~]
$ nmap -A -p 9001 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-28 00:46 -0400
Nmap scan report for 192.168.56.102
Host is up (0.0023s latency).

PORT      STATE SERVICE VERSION
9001/tcp  open  http    nginx
|_http-trane-info: Problem with XML parsing of /evox/about
|_http-title: Penpot - Design Freedom for Teams
MAC Address: 08:00:27:FD:20:08 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   2.30 ms  192.168.56.102

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.89 seconds

```

3. HTTP Enumeration Scripts

```
(kali㉿kali)-[~]
└─$ sudo nmap -sV --script http-enum,http-title,http-headers -p 9001 192.168.56.102
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-28 00:51 -0400
Nmap scan report for 192.168.56.102
Host is up (0.00094s latency).

PORT      STATE SERVICE VERSION
9001/tcp  open  http    nginx

| http-headers:
|   Server: nginx
|   Date: Thu, 28 May 2026 04:51:46 GMT
|   Content-Type: text/html; charset=utf-8
|   Content-Length: 257780
|   Last-Modified: Thu, 14 May 2026 13:24:45 GMT
|   Connection: close
|   Vary: Accept-Encoding
|   X-Content-Type-Options: nosniff
|   Referrer-Policy: strict-origin-when-cross-origin
|   Permissions-Policy: camera=(), microphone=(), geolocation=()
|   X-Frame-Options: SAMEORIGIN
|   Cache-Control: no-store, no-cache, max-age=0
|   Accept-Ranges: bytes
|
|_ (Request type: HEAD)
|_ http-title: Penpot - Design Freedom for Teams
MAC Address: 08:00:27:FD:20:08 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.04 seconds

(kali㉿kali)-[~]
```

Nikto

1. Basic Web Server Scan

```

+ Start Time: 2026-05-28 00:55:28 (GMT-4)
+ Server: nginx
+ ERROR: Failed to check for updates:
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [001535] /.psql_history: This might be interesting.
+ [001719] /js: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002748] /.mysql_history: Database SQL?.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007129] /.sqlite_history: This might be interesting.
+ [007203] /userdata.json: This might be interesting.
+ [007204] /login.json: This might be interesting.
+ [007205] /master.json: This might be interesting.
+ [007206] /masters.json: This might be interesting.
+ [007207] /connections.json: This might be interesting.
+ [007208] /connection.json: This might be interesting.
+ [007210] /PasswordsData.json: This might be interesting.
+ [007211] /users.json: This might be interesting.
+ [007212] /conndb.json: This might be interesting.
+ [007213] /conn.json: This might be interesting.
+ [007215] /accounts.json: This might be interesting.
+ [007303] /JAMonAdmin.jsp: JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2013-6235
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8309 requests: 0 errors and 22 items reported on the remote host
+ End Time: 2026-05-28 00:57:12 (GMT-4) (104 seconds)
+ 1 host(s) tested

```

2. Confirmation of findings (History Files)

```

curl -o /dev/null -s -w "%{http_code} %{url_effective}\n" \
  http://192.168.56.102:9001/.bash_history \
  http://192.168.56.102:9001/.sh_history \
  http://192.168.56.102:9001/.mysql_history \
  http://192.168.56.102:9001/.psql_history \
  http://192.168.56.102:9001/.htpasswd

```

```

(kali@kali)-[~]
$ curl -o /dev/null -s -w "%{http_code} %{url_effective}\n" http://192.168.56.102:9001/.htpasswd
200 http://192.168.56.102:9001/.htpasswd

(kali@kali)-[~]
$ curl -s http://192.168.56.102:9001/.htpasswd | head -5
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />

```

.htpasswd false positive

```

200 http://192.168.56.102:9001/.psql_history
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="utf-8" />
  <meta http-equiv="x-ua-compatible" content="ie=edge" />
  <title>Penpot - Design Freedom for Teams</title>

  <meta name="description" content="The open-source solution for design and prototyping.">
  <meta property="og:locale" content="en_US">
  <meta property="og:title" content="Penpot | Design Freedom for Teams">
  <meta property="og:description" content="The open-source solution for design and prototyping">
  <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
  <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
  <meta name="twitter:card" content="summary_large_image">
  <meta name="twitter:description" content="The open-source solution for design and prototyping">
  <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
  <meta name="twitter:site" content="@penpotapp">
  <meta name="twitter:creator" content="@penpotapp">
  <meta name="theme-color" content="#FFFFFF" media="(prefers-color-scheme: light)">
  <link id="theme" href="css/main.css?version=2.15.3-1778764938" rel="stylesheet" type="text/css" />
  <link href="css/ui.css?ts=2.15.3-1778764938" rel="stylesheet" type="text/css" />

  <link rel="icon" href="images/favicon.png?version=2.15.3-1778764938" />

  <script type="importmap">{"imports":{"./js/shared.js":"./js/shared.js?version=2.15.3-1778764938","./js/main.js":
"./js/main.js?version=2.15.3-1778764938","./js/render.js":"./js/render.js?version=2.15.3-1778764938","./js/render-wa
sm.js":"./js/render-wasm.js?version=2.15.3-1778764938","./js/rasterizer.js":"./js/rasterizer.js?version=2.15.3-17787
64938","./js/main-dashboards.js":"./js/main-dashboards.js?version=2.15.3-1778764938","./js/main-auth.js":"./js/main-au
th.js?version=2.15.3-1778764938","./js/main-viewer.js":"./js/main-viewer.js?version=2.15.3-1778764938","./js/main-se
ttings.js":"./js/main-settings.js?version=2.15.3-1778764938","./js/main-workspace.js":"./js/main-workspace.js?versio
n=2.15.3-1778764938","./js/util-highlight.js":"./js/util-highlight.js?version=2.15.3-1778764938"}}</script>

  <script type="module">
    globalThis.penpotVersion = "2.15.3";
    globalThis.penpotVersionTag = "2.15.3-1778764938";
    globalThis.penpotBuildDate = "Thu, 14 May 2026 13:22:18 +0000";
  </script>

```

.psql_history false positive

```

200 http://192.168.56.102:9001/.mysql_history
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="utf-8" />
  <meta http-equiv="x-ua-compatible" content="ie=edge" />
  <title>Penpot - Design Freedom for Teams</title>

  <meta name="description" content="The open-source solution for design and prototyping.">
  <meta property="og:locale" content="en_US">
  <meta property="og:title" content="Penpot | Design Freedom for Teams">
  <meta property="og:description" content="The open-source solution for design and prototyping">
  <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
  <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
  <meta name="twitter:card" content="summary_large_image">
  <meta name="twitter:description" content="The open-source solution for design and prototyping">
  <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
  <meta name="twitter:site" content="@penpotapp">
  <meta name="twitter:creator" content="@penpotapp">
  <meta name="theme-color" content="#FFFFFF" media="(prefers-color-scheme: light)">
  <link id="theme" href="css/main.css?version=2.15.3-1778764938" rel="stylesheet" type="text/css" />
  <link href="css/ui.css?ts=2.15.3-1778764938" rel="stylesheet" type="text/css" />

  <link rel="icon" href="images/favicon.png?version=2.15.3-1778764938" />

  <script type="importmap">{"imports":{"./js/shared.js":"./js/shared.js?version=2.15.3-1778764938","./js/main.js":
"./js/main.js?version=2.15.3-1778764938","./js/render.js":"./js/render.js?version=2.15.3-1778764938","./js/render-wa
sm.js":"./js/render-wasm.js?version=2.15.3-1778764938","./js/rasterizer.js":"./js/rasterizer.js?version=2.15.3-17787
64938","./js/main-dashboards.js":"./js/main-dashboards.js?version=2.15.3-1778764938","./js/main-auth.js":"./js/main-au
th.js?version=2.15.3-1778764938","./js/main-viewer.js":"./js/main-viewer.js?version=2.15.3-1778764938","./js/main-se
ttings.js":"./js/main-settings.js?version=2.15.3-1778764938","./js/main-workspace.js":"./js/main-workspace.js?versio
n=2.15.3-1778764938","./js/util-highlight.js":"./js/util-highlight.js?version=2.15.3-1778764938"}}</script>

  <script type="module">
    globalThis.penpotVersion = "2.15.3";
    globalThis.penpotVersionTag = "2.15.3-1778764938";
    globalThis.penpotBuildDate = "Thu, 14 May 2026 13:22:18 +0000";
  </script>

```

.mysql_history false positive

```
200 http://192.168.56.102:9001/.sh_history
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:site" content="@penpotapp">
    <meta name="twitter:creator" content="@penpotapp">
    <meta name="theme-color" content="#FFFFFF" media="(prefers-color-scheme: light)">
    <link id="theme" href="css/main.css?version=2.15.3-1778764938" rel="stylesheet" type="text/css" />
    <link href="css/ui.css?ts=2.15.3-1778764938" rel="stylesheet" type="text/css" />

    <link rel="icon" href="images/favicon.png?version=2.15.3-1778764938" />

    <script type="importmap">{"imports":{"./js/shared.js":"./js/shared.js?version=2.15.3-1778764938","./js/main.js":"./js/main.js?version=2.15.3-1778764938","./js/render.js":"./js/render.js?version=2.15.3-1778764938","./js/render-wasm.js":"./js/render-wasm.js?version=2.15.3-1778764938","./js/rasterizer.js":"./js/rasterizer.js?version=2.15.3-1778764938","./js/main-dashboards.js":"./js/main-dashboards.js?version=2.15.3-1778764938","./js/main-auth.js":"./js/main-auth.js?version=2.15.3-1778764938","./js/main-viewer.js":"./js/main-viewer.js?version=2.15.3-1778764938","./js/main-settings.js":"./js/main-settings.js?version=2.15.3-1778764938","./js/main-workspace.js":"./js/main-workspace.js?version=2.15.3-1778764938","./js/util-highlight.js":"./js/util-highlight.js?version=2.15.3-1778764938"}}</script>

    <script type="module">
      globalThis.penpotVersion = "2.15.3";
      globalThis.penpotVersionTag = "2.15.3-1778764938";
      globalThis.penpotBuildDate = "Thu, 14 May 2026 13:22:18 +0000";
    </script>
```

.sh_history false positive

```
200 http://192.168.56.102:9001/.bash_history
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:site" content="@penpotapp">
    <meta name="twitter:creator" content="@penpotapp">
    <meta name="theme-color" content="#FFFFFF" media="(prefers-color-scheme: light)">
    <link id="theme" href="css/main.css?version=2.15.3-1778764938" rel="stylesheet" type="text/css" />
    <link href="css/ui.css?ts=2.15.3-1778764938" rel="stylesheet" type="text/css" />

    <link rel="icon" href="images/favicon.png?version=2.15.3-1778764938" />

    <script type="importmap">{"imports":{"./js/shared.js":"./js/shared.js?version=2.15.3-1778764938","./js/main.js":"./js/main.js?version=2.15.3-1778764938","./js/render.js":"./js/render.js?version=2.15.3-1778764938","./js/render-wasm.js":"./js/render-wasm.js?version=2.15.3-1778764938","./js/rasterizer.js":"./js/rasterizer.js?version=2.15.3-1778764938","./js/main-dashboards.js":"./js/main-dashboards.js?version=2.15.3-1778764938","./js/main-auth.js":"./js/main-auth.js?version=2.15.3-1778764938","./js/main-viewer.js":"./js/main-viewer.js?version=2.15.3-1778764938","./js/main-settings.js":"./js/main-settings.js?version=2.15.3-1778764938","./js/main-workspace.js":"./js/main-workspace.js?version=2.15.3-1778764938","./js/util-highlight.js":"./js/util-highlight.js?version=2.15.3-1778764938"}}</script>

    <script type="module">
      globalThis.penpotVersion = "2.15.3";
      globalThis.penpotVersionTag = "2.15.3-1778764938";
```

.bash_history false positive

3. Confirmation of findings (JSON files)

```
curl -o /dev/null -s -w "%{http_code} %{url_effective}\n" \
  http://192.168.56.102:9001/userdata.json \
  http://192.168.56.102:9001/login.json \
  http://192.168.56.102:9001/users.json \
  http://192.168.56.102:9001/PasswordsData.json \
  http://192.168.56.102:9001/accounts.json
```

```
<script type="module" src="/js/tabs.js?version=2.15.3-1778764938"></script>
<script type="module">
  import { init } from "../js/main.js";
  import defaultTranslations from "../js/translation.en.js?version=2.15.3-1778764938";

  init({defaultTranslations});
</script>
</body>
</html>
200 http://192.168.56.102:9001/accounts.json
```

Accounts.json false positive

```
</html>
200 http://192.168.56.102:9001/PasswordsData.json
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
```

PasswordsData.json false positive

```
200 http://192.168.56.102:9001/users.json
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
```

users.json false positive

```
200 http://192.168.56.102:9001/login.json
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:site" content="@penpotapp">
```

login.json false positive

```
200 http://192.168.56.102:9001/userdata.json
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:site" content="@penpotapp">
```

Userdata.json false positive

4. Confirmation of findings (JAMon and other flagged paths)

```
curl -o /dev/null -s -w "%{http_code} %{url_effective}\n" \
  http://192.168.56.102:9001/JAMonAdmin.jsp \
```

<http://192.168.56.102:9001/js>

```
200 http://192.168.56.102:9001/JAMonAdmin.jsp
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Penpot - Design Freedom for Teams</title>

    <meta name="description" content="The open-source solution for design and prototyping.">
    <meta property="og:locale" content="en_US">
    <meta property="og:title" content="Penpot | Design Freedom for Teams">
    <meta property="og:description" content="The open-source solution for design and prototyping">
    <meta property="og:image" content="https://penpot.app/images/workspace-ui.jpg">
    <meta name="twitter:title" content="Penpot | Design Freedom for Teams">
    <meta name="twitter:card" content="summary_large_image">
    <meta name="twitter:description" content="The open-source solution for design and prototyping">
    <meta name="twitter:image" content="https://penpot.app/images/workspace-ui.jpg">
```

JAMonAdmin.jsp false positive

```
<script type="module" src="./js/libs.js?version=2.15.3-1778764938"></script>
<script type="module">
  import { init } from "./js/main.js";
  import defaultTranslations from "./js/translation.en.js?version=2.15.3-1778764938";

  init({defaultTranslations});
</script>
</body>
</html>
200 http://192.168.56.102:9001/js
(kali㉿kali)-[~]
$
```

/js false positive

Burpsuite

Projects - Your Penpot - x +

localhost:9001/#/dashboard/recent?team-id=5c2a40c4-ebc3-8142-8008...

Projects

Recent

Drafts 0 files, 20 seconds ago

Create new file Start building amazing stuff

Import a file Import a .penpot file

Libraries & Templates

Here you have some Libraries and templates you can add

DESIGN TOKENS starter.kit

Penpot Design

Design tokens starter kit + Penpot Design

BL Bobby Lee

Burp Suite

May 31 17:31

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator

Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited
1	http://localhost:9001	GET	/		
11	http://localhost:9001	GET	/api/main/methods/get-enabled-flags		
12	http://localhost:9001	GET	/api/main/methods/get-profile		
13	http://localhost:9001	HEAD	/		
14	http://localhost:9001	GET	/rasterizer.html		
19	http://localhost:9001	GET	/api/main/methods/get-profile		
20	http://localhost:9001	GET	/api/main/methods/get-teams		
21	http://localhost:9001	POST	/api/main/methods/logout		✓
24	http://localhost:9001	POST	/api/main/methods/prepare-register...		✓
25	http://localhost:9001	POST	/api/main/methods/register-profile		✓
26	http://localhost:9001	GET	/api/main/methods/get-profile		
27	http://localhost:9001	GET	/api/main/methods/get-teams		
28	http://localhost:9001	GET	/api/main/methods/get-teams		

Request Response

Pretty Raw Hex

```

like Gecko) Chrome/146.0.0.0 Safari/537.36
accept: application/transmit+json;text/event-stream,**
content-type: application/transmit+json
x-session-id: 05ed8069-7873-808d-8008-1b408086d52b
x-client: penpot-frontend/2.15.3
Origin: http://localhost:9001
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

{
  "username": "Bobby Lee",
  "email": "Bobby@GMAIL.COM",
  "password": "12345678"
}

```

Event log (1) All issues

Projects - Your Penpot - x +

localhost:9001/#/dashboard/recent?team-id=5c2a40c4-ebc3-8142-8008...

Projects

Recent

Drafts 0 files, 20 seconds ago

Create new file Start building amazing stuff

Import a file Import a .penpot file

Libraries & Templates

Here you have some Libraries and templates you can add

DESIGN TOKENS starter.kit

Penpot Design

Design tokens starter kit + Penpot Design

BL Bobby Lee

Burp Suite

May 31 17:31

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator

Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited
1	http://localhost:9001	GET	/		
11	http://localhost:9001	GET	/api/main/methods/get-enabled-flags		
12	http://localhost:9001	GET	/api/main/methods/get-profile		
13	http://localhost:9001	HEAD	/		
14	http://localhost:9001	GET	/rasterizer.html		
19	http://localhost:9001	GET	/api/main/methods/get-profile		
20	http://localhost:9001	GET	/api/main/methods/get-teams		
21	http://localhost:9001	POST	/api/main/methods/logout		✓
24	http://localhost:9001	POST	/api/main/methods/prepare-register...		✓
25	http://localhost:9001	POST	/api/main/methods/register-profile		✓
26	http://localhost:9001	GET	/api/main/methods/get-profile		
27	http://localhost:9001	GET	/api/main/methods/get-teams		
28	http://localhost:9001	GET	/api/main/methods/get-teams		

Request Response

Pretty Raw Hex

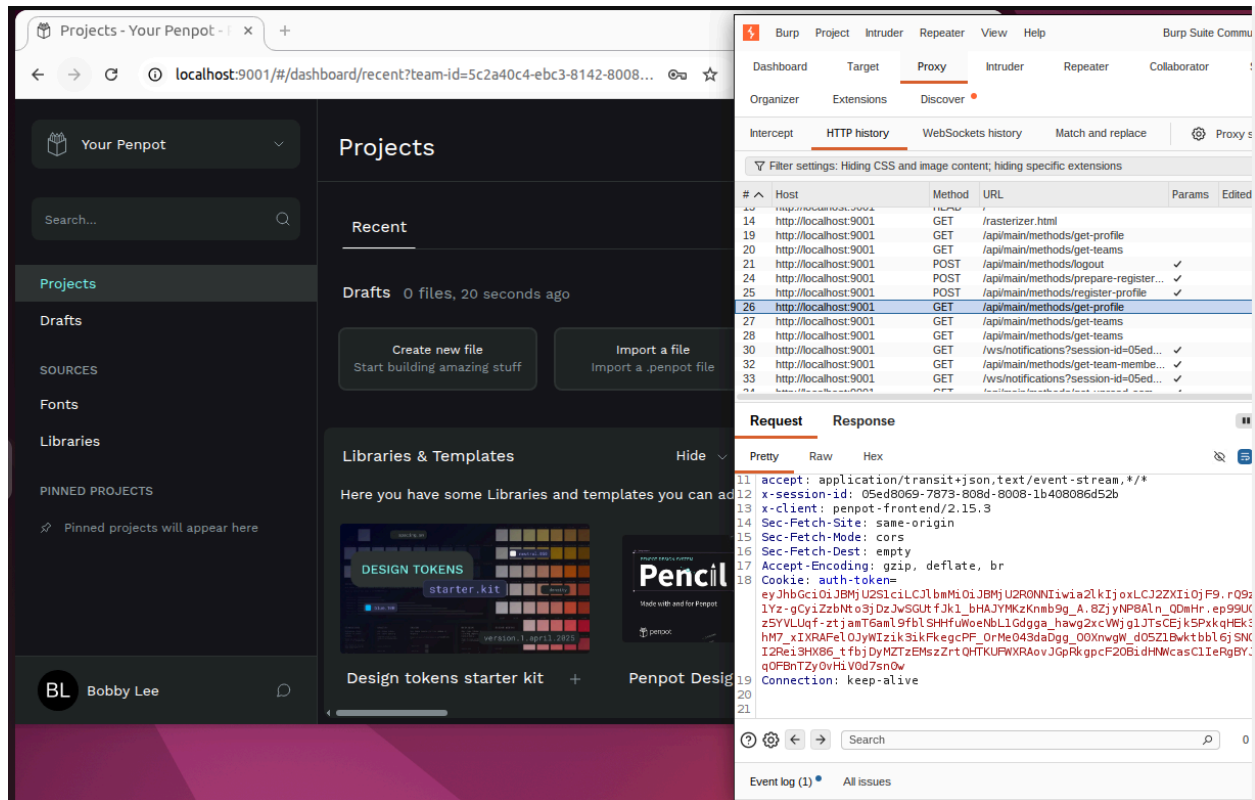
```

x-client: penpot-frontend/2.15.3
Origin: http://localhost:9001
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

{
  "token":
    "eyJhbGciOiJIc2E1ciIsImMiOiJBMjU2R0NDIn0.4LAFNC-Q2KKPQoDazS0d'
    LFTaJ9R3LPjJhRkTHeMDG53a-w.052Ps0tKgWOMyey6.0BGdIcYzoB1LkxN_aqZM'
    V1C0F84gCBN2VZD45jhh0i3K6d2c65V_c8aL0h0pTl_K85NbRAW7RNNs8Zf3rr'
    AsqWISYzT1Tj0THP0a0KEX21sbGff4F_3n7RbLYy7Aq1g7Lrc-zNU04vcTC7402U0'
    U260v6j0i0pYA03hh-jtC49wJlRfadrXmsbUN-Zl8MjLp80rvVU8r-guZcGtsjycE'
    mIX823luPTexzTLi62UowUXyizzM.t5xw_lhZX3y60-iCSaqhg"
}

```

Event log (1) All issues



Risk Assessment

Likelihood	Level of Impact				
	Very Low	Low	Moderate	High	Very High
Very High	Very Low	Low	Moderate	High	Very High
High	Very Low	Low	Moderate	High	Very High
Moderate	Very Low	Low	Moderate	Moderate	High
Low	Very Low	Low	Low	Low	Moderate
Very Low	Very Low	Very Low	Very Low	Low	Low

Summary & Analysis

Nikto flagged `.bash_history`, `.sh_history`, `.mysql_history`, `.psql_history`, and `.htpasswd` as potentially accessible (HTTP 200). Manual verification via curl confirmed that all five paths return Penpot's SPA index page rather than actual file content. This is a result of nginx's catch-all routing configuration returning HTTP 200 for unmatched routes. No sensitive history or credential files are exposed. Findings classified as false positives. The same behaviour was observed for all flagged JSON paths, including `/userdata.json`, `/login.json`, `/master.json`, `/masters.json`, `/connections.json`, `/connection.json`, `/PasswordsData.json`, `/users.json`, `/conndb.json`, `/conn.json`, and `/accounts.json`, as well as `/JAMonAdmin.jsp` and the `/js` directory reference. Each returned HTTP 200 with Penpot's standard SPA index HTML rather than the sensitive content Nikto anticipated. This pattern is consistent with the behaviour of single-page applications deployed behind nginx, where unmatched routes fall through to a catch-all that serves the frontend shell. Nikto's dictionary-based scanning approach does not inspect response body content, meaning any path in its database that receives a 200 status code is flagged regardless of whether the response contains the expected file. This inflated the apparent finding count significantly, and manual validation was required to distinguish true positives from SPA routing artifacts. All flagged directory and file findings from this scan are classified as false positives.

During a manual proxy-assisted assessment of the Penpot instance running at `localhost:9001` using Burp Suite Community Edition, several HTTP exchanges were captured and reviewed. The application responded correctly to standard requests, returning HTTP 200 status codes for valid routes and appropriate responses for authenticated API calls. The site map revealed a well-structured frontend built on compiled JavaScript modules including `main.js`, `main-auth.js`, `main-dashboard.js`, `main-workspace.js`, `render.js`, and `shared.js`, all versioned at `2.15.3-1778764938`, consistent with the Penpot version confirmed during the Nikto scan phase.

The API surface exposed through Burp's HTTP history revealed a RESTful backend accessible under the `/api/main/methods/` namespace. Observed endpoints included `get-enabled-flags`, `get-profile`, `get-teams`, `logout`, `prepare-register`, and `register-profile`. These endpoints handle core application functionality including authentication, team management, and user registration. All API communication uses `application/transit+json` as the content type, which is a Clojure-specific serialization format consistent with Penpot's ClojureScript backend architecture. The `x-client: penpot-frontend/2.15.3` header was observed on outbound requests, confirming the frontend version.

Session management was observed through two mechanisms. The application issues an x-session-id header used across API requests, and a separate auth-token cookie containing a JWT was observed in the get-profile request (Image 4). The JWT is transmitted in the Cookie header as auth-token and was visible in plaintext within Burp, which is expected in a local lab environment over HTTP. In a production deployment, this token should only be transmitted over HTTPS with appropriate Secure and HttpOnly cookie flags set to prevent interception and JavaScript access respectively.

During the registration flow, a plaintext POST request was captured to /api/main/methods/prepare-register containing the user's full name, email address, and password in cleartext within the request body (Image 2). This was followed by a second POST to /api/main/methods/register-profile which returned a JWT token in the response body (Image 3). The exposure of credentials in the request body is standard for registration flows, but reinforces the importance of enforcing HTTPS in any non-local deployment, as credentials transmitted over plain HTTP are trivially interceptable. This is not a vulnerability in Penpot's code, but a deployment-level concern for self-hosted instances that skip TLS configuration.

WebSocket connections were also observed under the /ws/notifications/ path, using session ID parameters appended to the URL to authenticate the WebSocket handshake. This pattern is consistent with Penpot's real-time collaboration features. The session ID in the WebSocket URL was also visible in the Burp site map under the ws folder, which could be a concern if server-side logging captures full WebSocket URLs, as session identifiers would appear in logs in plaintext.

Overall, the application behaves as expected for a locally deployed instance. The API structure is consistent and well-organized, authentication flows are functional, and no unexpected endpoints or error-based information leakage was observed during this assessment phase. The primary security observations relate to the absence of transport-layer encryption in the local deployment rather than application-level vulnerabilities, which is consistent with findings from the Nikto scan regarding missing security headers such as Strict-Transport-Security and Content-Security-Policy.

References

Canva. (n.d.). *Business features: Security and SSO*. Retrieved from <https://www.canva.com/business/features/security-ss/>

Canva. (n.d.). *Security at Canva*. Retrieved from <https://www.canva.com/security/>

Canva. (n.d.). *Trust & Security Portal*. Retrieved from <https://trust.canva.com/>

Figma. (n.d.). *Security: Peace of mind by design*. Retrieved from <https://www.figma.com/security/>

HackerOne. (n.d.). *Figma bug bounty program*. Retrieved from <https://hackerone.com/figma>

Huntress. (2025, November 14). *Canva data breach: What happened, impact, and lessons*. Retrieved from <https://www.huntress.com/threat-library/data-breach/canva-data-breach>

Penpot. (n.d.). *Security & Compliance Whitepaper*. Retrieved from <https://penpot.app/security-whitepaper>

Lab 4

Jeffrey Lam Ping Fong, Jacob Williams, Evan Bettencourt,
Easton Soares

WAS705 NBB

1st July 2027

Table of Contents

Authentication & Authorization And Fuzzing.....	3
Secret Management.....	17
Configuration File Review.....	17
Runtime Storage Inspection.....	19
Source and Git History Scan.....	20
Cryptographic Algorithm Review.....	21
Key Management Practices Review.....	22
API Security.....	23
Method Inventory and Documentation Exposure.....	23
Broken Object Level Authorization (BOLA, OWASP API1).....	25
Broken Function Level Authorization (BFLA, OWASP API5).....	27
Property Level Authorization / Mass Assignment (OWASP API3).....	28
Authentication Testing (OWASP API2).....	29
Rate Limiting and Resource Consumption (OWASP API4).....	31
Threat Modelling and Vulnerability Alignment.....	33
Threat Modelling Outcomes (Lab 2).....	33
Deprioritized threats.....	34
Known Vulnerabilities (Lab 1 and prior versions).....	34
Security Architecture & Diagrams.....	37
Security Unit Testing & Automation.....	39
Areas suitable for automated security testing.....	39
Proposed Basic Unit Tests.....	39

Authentication & Authorization And Fuzzing

Normal log in traffic

The screenshot displays the Burp Suite interface with the 'Request' and 'Response' tabs selected. The 'Request' tab shows a JSON body with user credentials, and the 'Response' tab shows a successful HTTP 200 status with a token in the response body.

Request	Response
<pre> 57659830-c61c-80c2-8008-4358b3972a2f 15 x-client: penpot-frontend/2.16.2 16 Origin: http://localhost:9001 17 Sec-Fetch-Site: same-origin 18 Sec-Fetch-Mode: cors 19 Sec-Fetch-Dest: empty 20 Accept-Encoding: gzip, deflate, br 21 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss; continueCode=wr2vVLqK6EBpb708jlXMyzxALDf3Sn2ImKu9rAZJmQRP5nwa3eoNWDg491Yr; 22 Connection: keep-alive 23 24 { "fullname": "Bobby Singh", "email": "Bobby@gmail.com", "password": "12345678" } </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: nginx 3 Date: Thu, 02 Jul 2026 00:56:02 GMT 4 Content-Type: application/transit+json 5 Connection: keep-alive 6 Vary: Accept-Encoding 7 Server-Timing: total;dur=0.04508348 8 X-Content-Type-Options: nosniff 9 Referrer-Policy: strict-origin-when-cross-origin 10 Permissions-Policy: camera=(), microphone=(), geolocation=() 11 X-Frame-Options: SAMEORIGIN 12 Content-Length: 432 13 14 { "token": "eyJhbGciOiJIbmJU2S1ciLCJlbmMiOiJIbmJU2RONnInO </pre>

First, I intercepted a normal login request. Burp Suite allowed me to view the full HTTP request and response between the client and the server. In the request, I could see the login endpoint, headers, and the JSON body containing the username and password. In the response, the server returned a successful HTTP 200 status along with an authentication token.

Created profile

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type
26	http://localhost:9001	GET	/ws/notifications/session-id=5/6...	✓		101	501	
25	http://localhost:9001	GET	/api/main/methods/get-teams			200	874	JSON
24	http://localhost:9001	GET	/api/main/methods/get-teams			200	874	JSON
23	http://localhost:9001	GET	/api/main/methods/get-profile			200	964	JSON
22	http://localhost:9001	POST	/api/main/methods/register-profile	✓		200	1499	JSON
21	http://localhost:9001	POST	/api/main/methods/prepare-regis...	✓		200	822	JSON
17	http://localhost:9001	POST	/api/main/methods/logout	✓		400	584	JSON
16	http://localhost:9001	GET	/api/main/methods/get-teams			401	501	JSON
14	http://localhost:9001	GET	/api/main/methods/get-profile			200	474	JSON
12	http://localhost:9001	GET	/api/main/methods/get-profile			200	473	JSON

Request

```

dismiss; welcomebanner_status=dismiss;
continueCode=
wr2vVLqK6EBpb708j1XMyzxALDf3Sn2ImKu9rAZJmQRP5n
wa3eoNWDg491Yr;
Connection: keep-alive
{
  "~:token":
  "eyJhbGciOiJIc2E1ciIsImMiOiJBMjU2R0NNIn0
  .10HxqlHN1xTSBgygW4FD_xgQDFKfoM8AdqvIHsxsIVm3
  bt02oBy4yJA.Vdljq3z3YQn2L0h.ZOKdzos9uZ6bBQR
  KmV5zSGT7jAaIc3ZzAjOFENZqJQN_KbyTdU69tS3I4fj
  MiCLzJKyJNBjNFJ290XZQr6XfGvSKTZAb2eidAcEjBW4
  CB9Zqb-deh_6DXUBKzxhSyx5VmSTSGghZDmmr3XJzyP
  whjI6ZSUIR3KI fSxseq40oqg2urr2UldNZzg-RYtnQj2
  k9gRC4eKTA7G7JIB-ZH9PwJpPQ-3lhXaWChTVgwp90IH
  nTKS3p2dWMDXRI6mvEywKhGdglfESuuc70MJQg.nd8-
  ialq8BkwpajouWGbJQ"
}

```

Response

```

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Thu, 02 Jul 2026 00:56:03 GMT
4 Content-Type: application/transit+json
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Set-Cookie: auth-token=
eyJhbGciOiJIc2E1ciIsImMiOiJBMjU2R0NNIn0
1kIjoxLCJ2ZXIiOiJF9.ZuEhBSfcFJ9rPXj4NSIb4X_9L51
tlih_n-7mZViY0alyu_-XHHxgjA.ZaTSTTdW-TcRInCF.H
q8ewmKJ06nQAN1xVLe1948v0P2BuDUSwTJ36WhQc0J0IMu
4eHrZ2i3rM6YrCivNvs8jSQdImZmPRZkUcN3z4WZz4XgZl
yHJZgdid00M-G5ET168JP3e9Isi00CnW5Z2MS-bP3wusrb
RygUFI6ym5TH_6AY1bn1JMvX79gdzSI1Uei6T7C9DM2CdT
10qX2N28AMmG-JqCuRcgEvX8ja0buFjsNZqV6CT5KRF5Q.
ObMZn0QAzy9GFtEsQ2kUmw; Path=/; HttpOnly;
Expires=Thu, 09 Jul 2026 00:56:03 GMT;
Comment=Renewal at: Thu, 2 Jul 2026 06:56:03
GMT; SameSite=Lax

```

In the request panel, we can see the registration data and the authentication-related headers. Capturing this request lets us verify that sensitive information is transmitted securely and helps identify parameters that can be tested for input validation.

Continuation code

The screenshot shows the Burp Suite interface with the Request and Response tabs selected. The Request tab on the left displays the following details:

- Request:**
 - 16 Sec-Fetch-Dest: empty
 - 17 Accept-Encoding: gzip, deflate, br
 - 18 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss; continueCode=wr2vVLqK6EBpb708j1MMyzxALDf3Sn2ImKu9rAZJmQRP5nwa3eoNWDg491Yk; auth-token=eyJhbGciOiJBMjU2S1ciLCJlbmMiOiJBMjU2R0NNIiwia2lkIjoxLCJ2ZXIiOiJF9uZuEhBSfcFJ9rPXj4NSIb4X_9L51tlih_n-7mZViY0alyu_-XHHxgja.ZaTSTTdW-TcRInCF.Hq8ewmKJ06nQANlxVLe1948vOP2BuDUSwTJ36WhQc0JOIMu4eHrZ2i3rM6YrCivNvs8jSqdTmZmPRZkUcN3z4WZz4XgZ1yHJzgdid00M-G5ET168JP3e9Isi00CnW5Z2MS-bP3wusrbRygUFI6ym5TH_6AY1bn1JMvX79gdzSI1Uei6T7C9DM2CdT10qX2N28AMmG-JqCuRcgEvX8ja0buFjsNZqV6CT5KRF5Q.0bMzn0QAzY9GfTEsQ2kUmw
 - 19 Connection: keep-alive

The Response tab on the right displays the following JSON object:

```
[
  {
    "email": "bobby@gmail.com",
    "is-demo": false,
    "auth-backend": "penpot",
    "fullname": "Bobby Singh",
    "modified-at": "ml782953763401",
    "is-active": true,
    "default-project-id": "ub31cdb39-b76b-80fd-8008-4358f196bbb1",
    "id": "ub31cdb39-b76b-80fd-8008-4358f191aab9",
    "is-authed": true
  }
]
```

On the left is the HTTP request captured by Burp Suite. Notice that the request now includes authentication cookies and tokens, which are automatically sent by the browser to prove the user's identity to the server. These session values are what allow the application to recognize the user without requiring them to log in again for every request.

Checking teams

The screenshot shows the Burp Suite interface with the Request and Response tabs selected. The Request tab on the left displays the following details:

- Request:**
 - 17 Accept-Encoding: gzip, deflate, br
 - 18 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss; continueCode=wr2vVLqK6EBpb708j1MMyzxALDf3Sn2ImKu9rAZJmQRP5nwa3eoNWDg491Yk; auth-token=eyJhbGciOiJBMjU2S1ciLCJlbmMiOiJBMjU2R0NNIiwia2lkIjoxLCJ2ZXIiOiJF9uZuEhBSfcFJ9rPXj4NSIb4X_9L51tlih_n-7mZViY0alyu_-XHHxgja.ZaTSTTdW-TcRInCF.Hq8ewmKJ06nQANlxVLe1948vOP2BuDUSwTJ36WhQc0JOIMu4eHrZ2i3rM6YrCivNvs8jSqdTmZmPRZkUcN3z4WZz4XgZ1yHJzgdid00M-G5ET168JP3e9Isi00CnW5Z2MS-bP3wusrbRygUFI6ym5TH_6AY1bn1JMvX79gdzSI1Uei6T7C9DM2CdT10qX2N28AMmG-JqCuRcgEvX8ja0buFjsNZqV6CT5KRF5Q.0bMzn0QAzY9GfTEsQ2kUmw
 - 19 Connection: keep-alive

The Response tab on the right displays the following JSON object:

```
[
  {
    "features": [
      {
        "set": [
          "fdata/path-data",
          "plugins/runtime",
          "design-tokens/v1",
          "variants/v1",
          "layout/grid",
          "styles/v2",
          "fdata/objects-map",
          "tokens/numeric-input",
          "render-wasm/v1",
          "components/v2",
          "fdata/shape-data-type"
        ]
      }
    ]
  }
]
```

On the left is the HTTP request sent to the server. The request contains the user's authentication cookies and session tokens, which verify that the request is coming from an authenticated user. Because this is a protected endpoint, only users with a valid session should be able to access it.

Checking team members

The screenshot shows the 'Request' and 'Response' tabs in a web browser's developer tools. The 'Request' tab on the left shows an HTTP request with headers like 'Accept-Encoding: gzip, deflate, br' and cookies including 'language=en', 'cookieconsent_status=dismiss', and 'welcomebanner_status=dismiss'. The 'Response' tab on the right shows a JSON object with fields like 'is-admin', 'email', 'team-id', 'name', 'fullname', and 'is-owner'.

On the left is the HTTP request, which includes the user's session cookies and authentication tokens. These credentials are required for the server to verify that the request is coming from an authenticated user with permission to access team information.

Correct email on the left Wrong email on the right

The screenshot shows a 'Word compare' tool comparing two HTTP requests. The left request (labeled '#1') has a 'Server-Timing' header with 'dur=0.100252084'. The right request (labeled '#2') has a 'Server-Timing' header with 'dur=0.004601708'. The tool highlights the difference in the duration values.

This behavior is important from a security perspective because it helps prevent account enumeration. If the application returned different error messages for valid and invalid email addresses, an attacker could determine which accounts exist simply by observing the responses.

Attempting brute forcing no odd one out

Request ^	Payload	Status code	Response r...	Error	Timeout	Length	Comment
0		400	175			471	
1	1234	400	114			472	
2	12	400	152			471	
3	4444	400	249			472	
4	123	400	119			472	
5	5666	400	136			471	
6	77765	400	308			471	
7	123124	400	165			471	
8	ev	400	228			471	
9	wa	400	268			471	
10	wdasd	400	165			471	
11	heth	400	99			471	
12	ukdty	400	105			472	
13	7867ue	400	114			471	
14	sdFSD	400	79			472	
15	ASDas	400	105			471	
16	asds	400	73			472	
17	12345678	400	77			472	

As shown in the results, every request returned the same HTTP **400 Bad Request** status code. The response lengths were also nearly identical, with only very small variations that are normal and do not indicate a successful login.

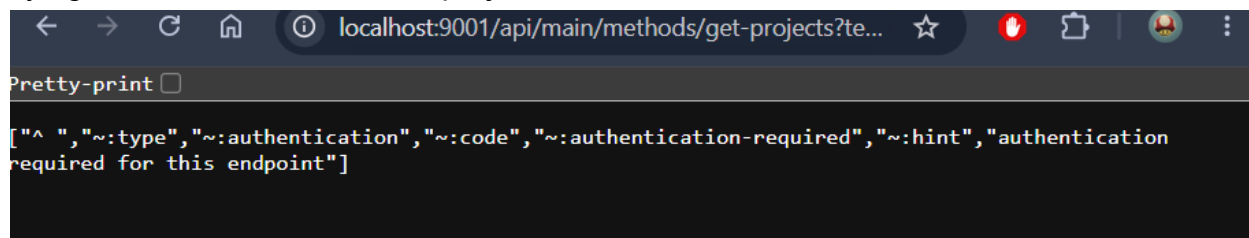
Brute forcing appears to work there is no limits to attempts

Request ^	Payload	Status code	Response rece...	Error	Timeout	Length	Comment
0		200	1576			1780	
1	123123	400	1370			435	
2	123123	400	873			436	
3	fsDF	400	866			436	
4	dfsdfs	400	1025			435	
5	dsfsdf	400	1098			436	
6	FDSf	400	500			436	
7	gr	400	492			435	
8	G	400	927			435	
9		400	130			635	
10	FSFS	400	189			436	
11	ef	400	794			436	
12	24423	400	600			435	
13	gsg	400	858			435	
14	fgdfg	400	777			436	
15		400	78			635	
16	gfdg	400	805			434	
17	f	400	238			436	
18		400	144			635	
19		400	89			635	
20		400	87			635	
21	sh	400	668			435	
22	hsrt	400	480			436	
23	hs	400	136			437	
24		400	144			633	
25	7	400	789			436	
26		400	26			635	
27	47w457	400	455			436	
28	12345678	200	719			1781	

As shown in the results, the majority of login attempts returned an HTTP 400 Bad Request, indicating that the credentials were invalid. However, the final request returned an HTTP 200 OK response, confirming that the correct password was successfully identified.

The key finding is that the application allowed all of these login attempts to be submitted without any noticeable rate limiting, account lockout, or CAPTCHA challenge. The requests continued uninterrupted until the correct password was eventually accepted.

trying to access another users project



Using Burp Suite, I modified the request by changing the project identifier to one that belonged to a different user and then replayed the request to the server. The objective was to determine whether the application properly enforced authorization checks or if it would allow unauthorized access to another user's resources.

Testing Null

Request		Response	
Pretty	Raw	Pretty	Raw
<pre> 14 application/transition+json 15 x-session-id: 16 57659830-c61c-80c2-8008-4358b3972a2f 17 x-client: penpot-frontend/2.16.2 18 Origin: http://localhost:9001 19 Sec-Fetch-Site: same-origin 20 Sec-Fetch-Mode: cors 21 Sec-Fetch-Dest: empty 22 Accept-Encoding: gzip, deflate, br 23 Cookie: language=en; 24 cookieconsent_status=dismiss; 25 welcomebanner_status=dismiss; 26 continueCode= 27 wr2vVLqK6EBpb708j1XMyzxALDf3Sn2ImKu9 28 rAZJmQRP5nwa3eoNWDg491Yfr; auth-token 29 = 30 eyJhbGciOiJIbWJU2S1ciLCJlbmMiOiJBMjU2 31 RONNIiwia2lkIjoxLCJ2ZXIiOiJF9.4EcQ8IH 32 Cj0x5tqnraklBrm-LXjdMFQofaaS15d9Vseo 33 HJtS05KZ1lw.b5ZLidYX5NNZrt-Z.xF3hP8_ 34 bCkEJd8MVQ9fryIOZIQAAL08rIOs_Gy62t56 35 QbsUJl4isc3kGJhv2olHzErdvilkxS3Pbrnz 36 GTceKPVwlbdiM2ig4WcHnK0CygeD70SX38eY 37 9JTWOrSoWY0PK5WkdzcwWkvOKa9d8yHXR5j5 38 EtFlwN1Hcj-Hfsfr66ldZ2r700y9ZcUrY4dU 39 cNcNUc4HSD8ytkl_23TofRCEI1NE8yOMrDmH 40 C29Rc5Q.JTGFX-Sfd0ZJ4qvdlQ-Fua 41 42 Connection: keep-alive 43 44 { 45 "profile-id": null 46 } </pre>		<pre> 1 HTTP/1.1 400 Bad Request 2 Server: nginx 3 Date: Thu, 02 Jul 2026 01:50:45 GMT 4 Content-Type: 5 application/transition+json 6 Connection: keep-alive 7 Server-Timing: total;dur=0.008717142 8 X-Content-Type-Options: nosniff 9 Referrer-Policy: 10 strict-origin-when-cross-origin 11 Permissions-Policy: camera=(), 12 microphone=(), geolocation=() 13 X-Frame-Options: SAMEORIGIN 14 Content-Length: 207 15 16 [17 { 18 "type": "validation", 19 "code": "invalid", 20 "params-validation": { 21 "profile-id": { 22 "errors": "\n[{:path [:profile-id 23 0], :in [:profile-id], :schema 24 :app.common.schema/uuid, :value 25 nil}]\n\nValue: \n(:profile-id 26 nil)\n\n" 27 } 28 } 29 } 30] </pre>	

On the left is the intercepted request in Burp Suite. Instead of providing a valid profile identifier, I changed the profile-id parameter to null to see how the application would respond to an unexpected or invalid input.

On the right is the server's response. The application returned an HTTP 400 Bad Request along with a detailed validation error indicating that the profile-id value was invalid. Rather than processing the request or causing an unexpected server error, the application correctly identified the invalid input and rejected it.

Non text

<pre> 14 application/transit+json x-session-id: 57659830-c61c-80c2-8008-4358b3972a2f 15 x-client: penpot-frontend/2.16.2 16 Origin: http://localhost:9001 17 Sec-Fetch-Site: same-origin 18 Sec-Fetch-Mode: cors 19 Sec-Fetch-Dest: empty 20 Accept-Encoding: gzip, deflate, br 21 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss; continueCode= wr2vVLqK6EBpb708j1XMyzxALDf3Sn2ImKu9 rAZJmQRP5nwa3eoNWDg491Yk; auth-token = eyJhbGciOiJBMjU2S1ciLCJlbmMiOiJBMjU2 RONNIiwia2lkIjoxLCJ2ZXIiOiJF9.4EcQ8IH Cj0x5tqmraklBrm-LXjdMFQofaaS15d9Vseo HJtS05KZ1lw.b5ZLidYX5NNZrt-Z.xF3hP8_ bCkEJd8MVQ9fryIOZIQAAl08rIOs_Cy62t56 QbsUJl4isc3kGJhv2olHzErdvilKxS3Pbrmz GTceKPVwlbdIM2ig4WcHnK0CygeD70SX38eY 9JTWOrSoWY0PK5WKDzcvWKVOKa9d8yHXR5j5 EtFlwNlHcj-HfSfr66ldZ2r700y9ZcUrY4dU cNcNUc4HSD8ytkl_Z3TofRCEI1NE8y0XQrDmH C29Rc5Q.JTGFX-Sfd0ZJ4qvdlQ-FuA 22 Connection: keep-alive 23 24 { "~:profile-id": 12345 } </pre>	<pre> 1 HTTP/1.1 400 Bad Request 2 Server: nginx 3 Date: Thu, 02 Jul 2026 01:51:14 GMT 4 Content-Type: application/transit+json 5 Connection: keep-alive 6 Server-Timing: total;dur=0.007881934 7 X-Content-Type-Options: nosniff 8 Referrer-Policy: strict-origin-when-cross-origin 9 Permissions-Policy: camera=(), microphone=(), geolocation=() 10 X-Frame-Options: SAMEORIGIN 11 Content-Length: 211 12 13 [{ "~:type", "~:validation", "~:code", "~:params-validation", "~:explain", "Errors:\n[{:path [:profile-id 0], :in [:profile-id], :schema :app.common.schema/uuid, :value 12345}]\n\nValue:\n{:profile-i d 12345}\n\n" }] </pre>
---	---

On the left, the intercepted request in Burp Suite shows the profile-id parameter being modified to an invalid value instead of a legitimate profile identifier. The purpose of this test was to determine whether the application properly validates the data type and format of user-supplied input.

On the right, the server responded with an HTTP 400 Bad Request and returned a validation error explaining that the profile-id value did not match the expected schema. Rather than attempting to process the invalid input or generating an internal server error, the application safely rejected the request.

Object

Request		Response	
Pretty	Raw	Pretty	Raw
<pre> 14 x-session-id: 57659830-c61c-80c2-8008-4358b3972a2f 15 x-client: penpot-frontend/2.16.2 16 Origin: http://localhost:9001 17 Sec-Fetch-Site: same-origin 18 Sec-Fetch-Mode: cors 19 Sec-Fetch-Dest: empty 20 Accept-Encoding: gzip, deflate, br 21 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss; continueCode= wr2vVLqK6EBpb708j1XMyzxALDf3Sn2ImKu9 rAZJmQRP5nwa3eoNWDg491Yr; auth-token = eyJhbGciOiJBMjU2S1ciLCJlbmMiOiJBMjU2 RONNIiwia2lkIjoxLCJ2ZXIiOiJF9.4EcQ8IH Cj0x5tqmraklBrm-LXjdMFQofaaS15d9Vseo HJtS05KZ1Iw.b5ZLidYX5NNZrt-Z.xF3hP8_ bCkEJd8MVQ9fryIOZIQAAL08rIOs_Gy62t56 QbsUJl4isc3kGJhv2olHzErdvilkxS3Pbrmz GTceKPVwlbdiM2ig4WcHnK0CygeD70SX38eY 9JTW0rSoWY0PK5WKDzcvWKVOKa9d8yHXR5j5 EtFlwNlHcj-HfSfr66ldZ2r700y9ZcUrY4dU cNcNUc4HSD8ytkl_Z3TofRCEI1NE8y0XkDmH C29Rc5Q.JTGFX-Sfd0ZJ4qvdlQ-FuA 22 Connection: keep-alive 23 24 { "~:profile-id": { } } </pre>		<pre> 1 HTTP/1.1 400 Bad Request 2 Server: nginx 3 Date: Thu, 02 Jul 2026 01:51:36 GMT 4 Content-Type: application/transit+json 5 Connection: keep-alive 6 Server-Timing: total;dur=0.007290681 7 X-Content-Type-Options: nosniff 8 Referrer-Policy: strict-origin-when-cross-origin 9 Permissions-Policy: camera=(), microphone=(), geolocation=() 10 X-Frame-Options: SAMEORIGIN 11 Content-Length: 205 12 13 { "~:type", "~:validation", "~:code", "~:params-validation", "~:explain", "Errors:\n[{:path [:profile-id 0], :in [:profile-id], :schema :app.common.schema/uuid, :value []}]\\n\\nValue:\n{profile-id []}\\n\\n" 14 } </pre>	

On the left, Burp Suite shows the intercepted request where the profile-id parameter has been changed to an object. This tests whether the application properly validates the structure and type of incoming data rather than simply accepting any JSON value.

On the right, the server returned an HTTP 400 Bad Request along with a validation error stating that the profile-id did not match the expected schema. Instead of processing the malformed request or generating an internal server error, the application safely rejected it.

List

Request	Response
<pre> 14 x-session-id: 57659830-c61c-80c2-8008-4358b3972a2f 15 x-client: penpot-frontend/2.16.2 16 Origin: http://localhost:9001 17 Sec-Fetch-Site: same-origin 18 Sec-Fetch-Mode: cors 19 Sec-Fetch-Dest: empty 20 Accept-Encoding: gzip, deflate, br 21 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss; continueCode= wr2vVLqK6EBpb708j1XMyzxALDf3Sn2ImKu9 rAZJmQRP5nwa3eoNWDg491Ykr; auth-token = eyJhbGciOiJBMjU2S1ciLCJlbmMiOiJBMjU2 RONNIiwia2lkIjoxLCJ2ZXkiOiJF9.4EcQ8IH Cj0x5tqprak1Brm-LXjdMFQofaaS15d9Vseo HJtS05KZ1lw.b5ZLidYX5NNZrt-Z.xF3hP8_ bCkEJd8MVQ9fryIOZIQAAL08rI0s_Gy62t56 QbsUJ14isc3kGJhv2olHzErdvilkxS3Pbrmz GTceKPVwlbdiM2ig4WcHnK0CygeD70SX38eY 9JTWOrSoWY0PK5WKDzcvWKV0Ka9d8yHXR5j5 EtFlwN1Hcj-HfSfr66ldZ2r700y9ZcUrY4dU cNcNUc4HSD8ytk1_Z3TofRCEI1NE8yOXxDmH C29Rc5Q.JTGFX-Sfd0ZJ4qvdlQ-FuA 22 Connection: keep-alive 23 24 { "~:profile-id": { </pre>	<pre> 1 HTTP/1.1 400 Bad Request 2 Server: nginx 3 Date: Thu, 02 Jul 2026 01:51:57 GMT 4 Content-Type: application/transit+json 5 Connection: keep-alive 6 Server-Timing: total;dur=0.020089207 7 X-Content-Type-Options: nosniff 8 Referrer-Policy: strict-origin-when-cross-origin 9 Permissions-Policy: camera=(), microphone=(), geolocation=() 10 X-Frame-Options: SAMEORIGIN 11 Content-Length: 205 12 13 ["~:type", "~:validation", "~:code", "~:params-validation", "~:explain", "Errors:\n[{:path [:profile-id 0], :in [:profile-id], :schema :app.common.schema/uuid, :value {}}]\n\nValue:\n{:profile-id { }}]\n\n" 14] </pre>

On the left, Burp Suite shows the intercepted request where the profile-id parameter has been modified to an array. The purpose of this test was to determine whether the application validates the expected data type and rejects values that do not match the required schema.

On the right, the server returned an HTTP 400 Bad Request along with a validation error indicating that the profile-id parameter was invalid. Rather than attempting to process the array or causing an unexpected server error, the application safely rejected the request.

Cant remove content type but can Change the forward and the reference

Request		Response	
Pretty	Raw	Pretty	Raw
<pre> 1 POST /api/main/methods/login-with-password HTTP/1.1 2 Host: localhost:9001 3 Content-Length: 53 4 sec-ch-ua-platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 x-frontend-version: 2.16.2 8 sec-ch-ua-mobile: ?0 9 x-external-session-id: null 10 x-event-origin: null 11 X-Forwarded-For: 127.0.0.1 12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 13 accept: application/transit+json,text/event-stream, */* 14 x-session-id: 57659830-c61c-80c2-8008-4358b3972a2f 15 x-client: penpot-frontend/2.16.2 16 Origin: evil.coml 17 Sec-Fetch-Site: same-origin 18 Sec-Fetch-Mode: cors 19 Sec-Fetch-Dest: empty 20 Accept-Encoding: gzip, deflate, br 21 Cookie: language=en; cookieconsent_status= dismiss; welcomebanner_status=dismiss; continueCode= wr2vVLqK6EBpb708j1MMyzxALDf3Sn2ImKu9rAZJmQR D5nva3e0NWDg481Vr </pre>		<pre> { "~:type", "~:validation", "~:code", "~:params-validation", "~:explain", "Errors:\n[{:path [:email], \n :in [:email],\n :schem a\n [:map\n {:title \"lo gin-with-password\"}\n [: email :app.common.schema/em ail]\n [:password [:app.c ommon.schema/word-string {: max 500}]]\n [:invitation -token {:optional true} [:a pp.common.schema/word-strin g {:max 6000}]]],\n :value nil,\n :type :malli.core/ missing-key)\n (:path [:pas sword],\n :in [:password], \n :schema\n [:map\n {: title \"login-with-password \"}\n [:email :app.common .schema/email]\n [:passwo rd [:app.common.schema/word -string {:max 500}]]\n [: invitation-token {:optional true} [:app.common.schema/ word-string {:max 6000}]]], \n :value nil,\n :type :m alli.core/missing-key))\n\n Value:\n{}\n\n" </pre>	

During this test, I attempted to remove or modify several HTTP headers. Some headers, such as Content-Type, could not be removed because Burp Suite automatically requires them for the request to remain valid. However, I was able to modify headers such as X-Forwarded-For, Origin, and Referer to simulate requests coming from different IP addresses or websites. This type of testing is important because attackers often modify headers like X-Forwarded-For to spoof their IP address or change the Origin and Referer headers in an attempt to bypass security controls or exploit poorly configured access restrictions.

can change the continuation code

```

1 GET /api/main/methods/get-profile HTTP/1.1
2 Host: localhost:9001
3 sec-ch-ua-platform: "Windows"
4 Accept-Language: en-US,en;q=0.9
5 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 sec-ch-ua-mobile: ?0
7 x-frontend-version: 2.16.2
8 x-external-session-id: null
9 x-event-origin: null
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
    AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
    Safari/537.36
11 accept: application/transit+json,text/event-stream,*/**
12 x-session-id: 57659830-c61c-80c2-8008-4358b3972a2f
13 x-client: penpot-frontend/2.16.2
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Accept-Encoding: gzip, deflate, br
18 Cookie: language=en; cookieconsent_status=dismiss;
    welcomebanner_status=dismiss; continueCode=abc; auth-token=
    eyJhbGciOiJIc2EiLCJlbmMiOiJBMjU2R0NNIiwia2lkIjoxLCJ2ZXIiOi
    jF9.4EcQ8IHCj0x5tqnraKlBrm-LXjdMFQofaaS15d9VseoHJtS05KZlIw.b5
    ZLidYX5NNZRt-Z.xF3hP8_bChEjd8MVQ9fryIOZIQAAl08rIOs_Gy62t56Qbs
    UJl4isc3kGJhv2olHzErdvilkxS3PbrmzGTceKPVwlbdiM2ig4WcHnK0CygeD
    70SX38eY9JTW0rSoWY0PK5WKDzcvWKVOKa9d8yHXR5j5EtFlwN1Hcj-HfSfr6
    6ldZ2r700y9ZcUrY4dUcNcNUc4HSD8ytkl_Z3TofRCEI1NE8y0XGrDmHC29Rc5
    Q.JTGFX-Sfd0ZJ4qvdlQ-FuA
19 Connection: keep-alive

```

After logging in, I intercepted an authenticated request and manually edited the session-related values, including the continuation code and authentication token, before forwarding the request to the server.

The purpose of this test was to determine whether the server relied solely on the client-provided token or whether it properly validated the session against its own records. If the application accepted a modified token, it could indicate a vulnerability such as session fixation, session prediction, or improper session validation.

The sql injections doesnt error but doesnt go ththrough

```

Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate, br
Cookie: language=en; cookieconsent_status=dismiss;
welcomebanner_status=dismiss; continueCode=' OR 1=1--;
auth-token=
eyJhbGciOiJIbWJU2S1ciLCJlbmMiOiJBMjU2R0NNIiwia2lkIjoxLCJ2ZXIiOi
jF9.4EcQ8IHCj0x5tqnra:1Brm-LXjdMFQofaaS15d9VseoHJtS05KZ1Iw.b5
ZLidYX5NNZRt-Z.xF3hP8_bCkEJd8MVQ9fryIOZIQAAl08rIOs_Gy62t56Qbs
UJl4isc3kGJhv2olHzErdvilkxS3PbrmzGTeeKPVwlbdiM2ig4WcHnK0CygeD
70SX38eY9JTW0rSoWY0PK5WKDzcvWKVOKa9d8yHXR5j5EtFlwN1Hcj-HfSfr6
6ldZ2r700y9ZcUrY4dUcNcNUc4HSD8ytkl_Z3TofRCEI1NE8y0XQrDmHC29Rc5
Q.JTGFX-Sfd0ZJ4qvdlQ-FuA
Connection: keep-alive
.....

```

This is a positive security result because it indicates that Penpot is not directly inserting user input into SQL queries without validation. The application likely uses parameterized queries, prepared statements, or server-side validation to prevent SQL injection attacks.

Secret Management

Configuration File Review

Identifying hardcoded secrets and default credentials in the deployment's primary configuration source

```

user@Router:~$ grep -nE 'SECRET_KEY|PASSWORD|POSTGRES_PASSWORD|_KEY|_URI|SMTP_|AWS_' docker-compose.yml
30:  PENPOT_PUBLIC_URI: http://192.168.56.107:9001
46:  PENPOT_SECRET_KEY: change-this-insecure-key
137:  PENPOT_DATABASE_URI: postgresql://penpot-postgres/penpot
139:  PENPOT_DATABASE_PASSWORD: penpot
144:  PENPOT_REDIS_URI: redis://penpot-valkey/0
154:  # AWS_ACCESS_KEY_ID: <KEY_ID>
155:  # AWS_SECRET_ACCESS_KEY: <ACCESS_KEY>
173:  PENPOT_SMTP_DEFAULT_FROM: no-reply@example.com
174:  PENPOT_SMTP_DEFAULT_REPLY_TO: no-reply@example.com
175:  PENPOT_SMTP_HOST: penpot-mailcatch
176:  PENPOT_SMTP_PORT: 1025
177:  PENPOT_SMTP_USERNAME:
178:  PENPOT_SMTP_PASSWORD:
179:  PENPOT_SMTP_TLS: "false"
180:  PENPOT_SMTP_SSL: "false"
203:  PENPOT_PUBLIC_URI: http://penpot-frontend:8080
206:  PENPOT_REDIS_URI: redis://penpot-valkey/0
230:  - POSTGRES_PASSWORD=penpot
user@Router:~$

```

The assessment began with a review of the docker-compose.yml file, which serves as the primary configuration source for the deployment and defines the environment in which every Penpot service runs. A targeted search of this file for credential-bearing and key-bearing variables surfaced several secrets that appear to be stored in plaintext and shipped as defaults.

The most significant finding is the application master key, defined on line 46 as `PENPOT_SECRET_KEY: change-this-insecure-key`. This value is not a placeholder that the application refuses to start without, but a functioning default that is committed to a public repository. Its exposure is consequential because the master key seeds the derivation of all subsystem keys, so a known value of this kind would allow the derived keys to be reproduced by anyone who has read the shipped configuration.

The database credentials appear to be similarly weak and hardcoded. The connection string on line 137 (`PENPOT_DATABASE_URI: postgresql://penpot-postgres/penpot`) uses the database

name penpot, and the associated password is set to the same trivial value on line 139 (PENPOT_DATABASE_PASSWORD: penpot). The corresponding PostgreSQL container is configured with the identical password on line 230 (POSTGRES_PASSWORD=penpot), which suggests the default credential pair is reused rather than randomised at deployment. The Redis and Valkey connection defined on line 144 (PENPOT_REDIS_URI: redis://penpot-valkey/0) contains no authentication component, which indicates that the caching and notification layer is reachable without credentials within the container network.

Several further observations are worth recording, though they appear lower in severity. The SMTP configuration on lines 173 through 180 leaves both PENPOT_SMTP_USERNAME and PENPOT_SMTP_PASSWORD empty and disables TLS and SSL, which is consistent with the bundled mail-catching service used for local testing rather than a production mail path. The Amazon Web Services credentials on lines 154 and 155 are present only as commented-out examples and are therefore not active in this deployment, but they are noted for completeness because they mark the place where live keys would be introduced if object storage were later moved to S3.

Taken together, these results establish that the deployment stores its secrets directly in a plaintext configuration file and relies on shipped default values for its most sensitive credentials, including the master key from which all other keys are derived.

We also had to find out whether the secrets defined in the configuration file are also exposed at runtime through the deployed containers. Confirming this establishes that the exposure is not confined to the source file but extends to the live environment, where the same values are held in plaintext and can be retrieved by any process able to query the Docker daemon.

```
user@Router:~$ docker ps
```

CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAMES
fc22c4254c75	penpotapp/frontend:2.16	"/bin/bash /entrypoi..."	11 minutes ago	Up 11 minutes	0.0.0.0:9001->8080/tcp, [::]:9001->8080/tcp	penpot_penpot-front
end_1						
e6f8a2d68c51	penpotapp/backend:2.16	"/bin/bash run.sh"	11 minutes ago	Up 11 minutes		penpot_penpot-backe
nd_1						
6f4992472547	penpotapp/exporter:2.16	"node app.js"	11 minutes ago	Up 11 minutes		penpot_penpot-expor
ter_1						
d56d3c3e12b1	sj26/mailcatcher:latest	"mailcatcher --foreg..."	11 minutes ago	Up 11 minutes	1025/tcp, 0.0.0.0:1080->1080/tcp, [::]:1080->1080/tcp	penpot_penpot-mailc
atch_1						
eb57487cdb39	penpotapp/mcp:2.16	"node index.js --mul..."	11 minutes ago	Up 11 minutes		penpot_penpot-mcp_1
15c6414aa88b	postgres:15	"docker-entrypoint.s..."	11 minutes ago	Up 11 minutes (healthy)	5432/tcp	penpot_penpot-postg
res_1						
e5ad9daac705	valkey/valkey:8.1	"docker-entrypoint.s..."	11 minutes ago	Up 11 minutes (healthy)	6379/tcp	penpot_penpot-valke
u_1						

The running services were first enumerated to obtain their exact names. Because the stack was launched under the project name penpot, Compose prefixes each container accordingly, producing names such as penpot_penpot-backend_1, penpot_penpot-frontend_1, and penpot_penpot-postgres_1.

```

user@Router:~$ docker inspect penpot_penpot-backend_1 --format '{{range .Config.Env}}{{println .}}{{end}}'
PENPOT_SECRET_KEY=change-this-insecure-key
PENPOT_HTTP_SERVER_MAX_BODY_SIZE=367001600
PENPOT_HTTP_SERVER_MAX_MULTIPART_BODY_SIZE=367001600
PENPOT_PUBLIC_URI=http://192.168.56.107:9001
PENPOT_FLAGS=disable-email-verification enable-smtp enable-prepl-server disable-secure-session-cookies enable-mcp
PENPOT_DATABASE_URI=postgresql://penpot-postgres/penpot
PENPOT_DATABASE_USERNAME=penpot
PENPOT_DATABASE_PASSWORD=penpot
PENPOT_REDIS_URI=redis://penpot-valkey/0
PENPOT_OBJECTS_STORAGE_BACKEND=fs
PENPOT_OBJECTS_STORAGE_FS_DIRECTORY=/opt/data/assets
PENPOT_TELEMETRY_ENABLED=true
PENPOT_TELEMETRY_REFERER=compose
PENPOT_SMTP_DEFAULT_FROM=no-reply@example.com
PENPOT_SMTP_DEFAULT_REPLY_TO=no-reply@example.com
PENPOT_SMTP_HOST=penpot-mailcatch
PENPOT_SMTP_PORT=1025
PENPOT_SMTP_USERNAME
PENPOT_SMTP_PASSWORD
PENPOT_SMTP_TLS=false
PENPOT_SMTP_SSL=false
PATH=/opt/jre/bin:/opt/node/bin:/opt/imagick/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
LANG=C.UTF-8
LC_ALL=C.UTF-8
JAVA_HOME=/opt/jre
DEBIAN_FRONTEND=noninteractive
TZ=Etc/UTC

```

The backend container's environment was then inspected, as this is where the master key and database credentials are injected at runtime.

The output listed the sensitive values in cleartext, confirming that they are stored unencrypted in the container configuration. Most notably, `PENPOT_SECRET_KEY=change-this-insecure-key` and `PENPOT_DATABASE_PASSWORD=penpot` appeared directly in the environment, matching the default values identified in the configuration file. The same inspection also revealed related security-relevant settings, including `PENPOT_TELEMETRY_ENABLED=true`, which enables anonymous data reporting by default, and a `PENPOT_FLAGS` value containing `disable-email-verification` and `disable-secure-session-cookies`, both of which weaken account and session protections in the running instance.

Runtime Storage Inspection

Confirming plaintext exposure of secrets through the Docker daemon and running process environment

```

user@Router:~$ docker exec penpot_penpot-backend_1 env | grep -E 'SECRET|PASSWORD|_KEY'
PENPOT_SECRET_KEY=change-this-insecure-key
PENPOT_DATABASE_PASSWORD=penpot
user@Router:~$

```

To demonstrate that these values persist in the live process environment rather than existing only in the daemon's stored metadata, the same variables were read from inside the running container.

This returned `PENPOT_SECRET_KEY=change-this-insecure-key` and `PENPOT_DATABASE_PASSWORD=penpot`, confirming that the master key and database password are readable from within the process environment itself.

These results confirm that the secrets are exposed at multiple layers of the deployment. Beyond their presence in the plaintext configuration file, they remain readable through the Docker daemon and from within the running process environment, neither of which provides encryption or access control appropriate to material of this sensitivity.

Source and Git History Scan

Detecting committed secrets and key material within the application repository and its version history

```
user@Router:~$ gitleaks detect --source ./penpot --no-banner -v
Finding: -----BEGIN PRIVATE KEY-----
MIIEvQIBADANBgkqhkiG9w0BAQEFAASCBCwggSjAgEAAoIBAQDJUiv+kg8T5DIv
+rshA6K...
Secret: -----BEGIN PRIVATE KEY-----
MIIEvQIBADANBgkqhkiG9w0BAQEFAASCBCwggSjAgEAAoIBAQDJUiv+kg8T5DIv
+rshA6K...
RuleID: private-key
Entropy: 6.017375
File: docker/devenv/files/selfsigned.key
Line: 1
Commit: 6d458c80a196c96b5aaa2be580dad25aa49f7b55
Author: Belén Albeza
Email: belen.albeza@kaleidos.net
Date: 2026-07-01T18:15:20Z
Fingerprint: 6d458c80a196c96b5aaa2be580dad25aa49f7b55:docker/devenv/files/selfsigned.key:private-key:1

2:27AM INF 1 commits scanned.
2:27AM INF scan completed in 8.99s
2:27AM WRN leaks found: 1
```

We then assessed whether secrets are embedded in the application source code or its version history, since credentials committed to a repository remain retrievable even after later removal. The Penpot repository was cloned to the assessment host and scanned with an automated secret-detection tool across its tracked contents and commit history.

The scan reported one finding. The private-key rule matched a PEM-encoded private key stored at `docker/devenv/files/selfsigned.key`, beginning with the standard `-----BEGIN PRIVATE KEY-----` header and carrying a high entropy value of approximately 6.02, which is consistent with genuine key material rather than a placeholder. The key is committed to the repository and attributable to a specific author and commit within the project history, confirming that it is distributed with the source rather than introduced locally during this deployment.

The exposed key belongs to the development environment, as indicated by its `docker/devenv/` path, and is a self-signed certificate key intended for local development rather than production use. Its severity in a production context is therefore lower than that of the master key identified

earlier. It remains a valid finding, however, because a private key committed to a public repository is known to every party who obtains the source, offers no confidentiality if reused, and represents exactly the class of hardcoded secret that source scanning is intended to surface. Its presence also demonstrates that the project's version history contains at least one piece of real cryptographic key material, which reinforces the need to treat committed secrets as compromised. This confirms that hardcoded secrets are present not only in the deployment's environment configuration but also within the source repository itself.

Cryptographic Algorithm Review

Evaluating the strength of the algorithms used for password hashing, token protection, and key derivation

```
user@Router:~$ cd penpot/
user@Router:~/penpot$ grep -nE ':alg|:memory|:iterations|:parallelism|argon2' backend/src/app/auth.clj
12: {:alg :argon2id
13:  :memory 32768 ;; 32 MiB
14:  :iterations 3
15:  :parallelism 2})
user@Router:~/penpot$ grep -nE ':alg|:enc|jwe|a256' backend/src/app/tokens.clj
15: [buddy.sign.jwe :as jwe]))
31: (jwe/encrypt payload tokens-key {:alg :a256kw :enc :a256gcm :header header})))
36: (jwe/decode-header token))
44: (jwe/decrypt token tokens-key {:alg :a256kw :enc :a256gcm}))
user@Router:~/penpot$ grep -nE ':alg|:digest|hkdf|blake2b|derive' backend/src/app/setup/keys.clj
9: (:refer-clojure :exclude [derive])
13:(defn derive
20:      :alg :hkdf
21:      :digest :blake2b-512}))
user@Router:~/penpot$
```

We then evaluated the strength of the cryptographic algorithms applied by the application, examining the three locations where cryptography is used: password hashing, token protection, and key derivation. Each was inspected directly in the source to identify the algorithm and its configured parameters. Password hashing was reviewed in `backend/src/app/auth.clj`

The output showed passwords hashed with Argon2id (`:alg :argon2id`) configured with a memory cost of 32768 KiB, or 32 MiB, three iterations, and a parallelism of two. Argon2id is the algorithm currently recommended for password storage, and the configured parameters meet accepted guidance, so this represents a strong choice.

It also confirmed that tokens are handled as JSON Web Encryption rather than plain signed tokens, using the `buddy.sign.jwe` library. The encryption is configured with `:alg :a256kw` and `:enc :a256gcm`, meaning AES-256 key wrapping combined with AES-256-GCM authenticated encryption. This provides both confidentiality and integrity for issued tokens, and it avoids the signature-only weaknesses associated with unencrypted JSON Web Tokens. This is likewise a strong configuration.

It then showed keys derived through HKDF (`:alg :hkdf`) using a BLAKE2b-512 digest (`:digest :blake2b-512`). HKDF is the standard construction for deriving subordinate keys from a single

input, and BLAKE2b-512 is a modern, strong digest, so the derivation mechanism itself is sound.

The conclusion drawn at this stage is that the deployment's cryptographic weakness does not lie in the algorithms selected. Each of the three applications of cryptography uses a current, well-regarded algorithm with appropriate parameters. The weakness identified in earlier stages is instead one of key material: strong, authenticated encryption and sound key derivation offer no protection when the master secret from which every key is derived is a publicly known default value.

Key Management Practices Review

Assessing the derivation, storage, and rotation of the master secret from which all keys descend.

```
user@Router:~/penpot$ grep -nE 'secret-key|tokens-key|derive|generate-random-key' backend/src/app/setup.clj
25:(defn- generate-random-key
33:  (filter #(not= "secret-key" (:id %)))
90:    (l/wrn :hint (str "using autogenerated secret-key, it will change ")
95:      (let [secret (or key (generate-random-key))]
97:        (assoc :secret-key secret)
98:        (assoc :tokens-key (keys/derive secret :salt "tokens")))
103:  (let [secret (get props :secret-key)]
106:    (-> (keys/derive secret :salt (name id))
user@Router:~/penpot$
```

We assessed how cryptographic key material is managed across its lifecycle. The setup logic in backend/src/app/setup.clj was examined to establish the dependency relationships between the master secret and the keys derived from it.

The output established that the deployment relies on a single master secret. Line 95 shows that the secret is taken from the supplied key where one is configured, and only falls back to generate-random-key when none is provided. Lines 97 and 98 show that this secret is stored as secret-key and then used to derive the tokens-key through keys/derive with the salt "tokens", and line 106 shows the same derivation pattern applied to further subsystem keys, each distinguished by its own salt. This confirms that the token key and every other subsystem key descend from the one master value, so the security of the entire scheme rests on that single secret remaining confidential and unique to each deployment.

In the configuration examined, it is neither. As established in the earlier stages, the master secret is a fixed default (change-this-insecure-key) committed to a public repository and injected through an environment variable that is readable both through the Docker daemon and from within the process environment. No rotation mechanism is provided or documented for it.

A relevant observation from the same source appears on line 90, where the application emits a warning that an autogenerated secret key will change on each restart and recommends setting the key explicitly. This warning is only reached when no key is supplied. Shipping a hardcoded

default in the compose file satisfies the supplied-key condition on line 95, so the fallback path and its warning never activate, and the safeguard intended to prompt an operator to configure a proper key is effectively suppressed in the default deployment.

The key management review completes the assessment across all three sub-tasks. Secrets are stored and used in plaintext at the configuration, daemon, and process layers; hardcoded default credentials, a default master key, and a committed development private key represent the principal instances of insecure storage; and while the cryptographic algorithms are strong, the absence of unique key generation, secure storage, and rotation for the master secret undermines the protection those algorithms would otherwise provide.

API Security

Penpot does not use a normal REST or GraphQL API. The backend exposes an RPC API where every call is an HTTP request to `/api/main/methods/<method-name>`, with parameters sent as `transit+json` by default. The server also accepts plain JSON when the `Accept` and `Content-Type` headers are set, which was done throughout, so the responses were readable. All testing was performed against a self-hosted Penpot 2.16 instance at `192.168.56.102:9001`, deployed with Docker, using Burp Suite Pro as the intercepting proxy. Testing used two registered users in separate teams (userA, owner of TeamA, and userB, owner of TeamB) plus a third low-privilege user (userC, a Viewer in TeamA) for the authorization tests.

The screenshot displays the Burp Suite interface. On the left, a tree view shows the API structure under the host `192.168.56.102:9001`, with a folder named `api` containing a `main` folder and a `methods` folder. The `main` folder is expanded, showing a list of methods. The main panel shows a table of HTTP requests and responses, with columns for Host, Method, URL, Params, Status code, Length, MIME type, and Title. The table lists 20 requests, all with a status code of 200 and a MIME type of JSON. The bottom panel shows the details of a selected request, including the Request and Response tabs, and the Inspector panel showing request attributes and headers.

Host	Method	URL	Params	Status code	Length	MIME type	Title
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	939	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	4060	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	4060	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	719	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	686	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	532	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	532	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	631	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	631	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	631	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	722	JSON	
http://192.168.56.102...	POST	/api/main/methods/cr...	✓	200	722	JSON	
http://192.168.56.102...	GET	/api/main/methods/ge...		200	530	JSON	
http://192.168.56.102...	GET	/api/main/methods/ge...	✓	200	1240	JSON	
http://192.168.56.102...	GET	/api/main/methods/ge...	✓	200	391	JSON	
http://192.168.56.102...	GET	/api/main/methods/ge...	✓	200	391	JSON	
http://192.168.56.102...	GET	/api/main/methods/ge...		200	415	JSON	

Method Inventory and Documentation Exposure

The first step was enumerating the full attack surface. Penpot ships a built-in API documentation endpoint at `/api/main/doc` that lists all RPC methods and their parameter schemas. This endpoint is gated behind the `enable-backend-api-doc` flag and is off by default, which is the correct secure default. It was enabled on the test instance for white-box discovery. Browsing it as an authenticated user returned the full methods reference: the auth methods (login-with-password, logout, recover-profile, register-profile, verify-token), access-token methods, file methods (get-file, create-file, update-file), team methods, and the binfile import/export methods.

Burp's site map provided a second view by capturing the real RPC calls the frontend made during normal use, with everything under `/api/main/methods/` appearing as live endpoints to target.

The doc endpoint was then tested for access without authentication, since an exposed method list with full schemas is useful reconnaissance (OWASP API9, Improper Inventory Management). The GET `/api/main/doc` request was sent to Repeater, the Cookie header was removed entirely, and it was resent. The server returned the full API documentation with a 200 status and no session present, so the complete method inventory is exposed to unauthenticated clients when the flag is on. Severity is low because the flag is off by default, so a stock deployment is not exposed, but in any instance where an administrator enabled it leaks the inventory to anyone.

Method	OWASP	Test	Expected	Actual	Verdict
GET <code>/api/main/doc</code>	API9	Enumerate RPC methods (authenticated)	method list returned	full methods reference captured as inventory	Informational
GET <code>/api/main/doc</code>	API9	Access API docs without authentication	401 / redirect	200, full method list with no cookie	Vulnerable (low, default-off)

```
192.168.56.102:9001/api/main/doc
```

```
{
  "id": "db601c95-045f-808b-8002-362f08fcb621",
  "name": "rename-file",
  "props": <payload>,
  "profileId": "db601c95-045f-808b-8002-361312e63531"
}
```

METHODS REFERENCE:

access-token:	create-access-token	AUTH SCHEMA
access-token:	delete-access-token	AUTH SCHEMA
access-token:	get-access-tokens	AUTH SCHEMA
access-token:	get-current-mcp-token	DEPRECATED AUTH SCHEMA
auth:	get-sso-provider	SCHEMA
auth:	login-with-ldap	SCHEMA
auth:	login-with-password	SCHEMA
auth:	logout	SCHEMA
auth:	prepare-register-profile	SCHEMA
auth:	recover-profile	SCHEMA
auth:	register-profile	SCHEMA
auth:	request-profile-recovery	SCHEMA
auth:	verify-token	SCHEMA
binfile:	export-binfile	AUTH WEBHOOK SCHEMA
binfile:	import-binfile	AUTH WEBHOOK SCHEMA

The screenshot shows the Burp Suite Professional v2026.4.3 interface. The 'Repeater' tab is active, displaying a single request. The request is a GET to `/api/main/doc` with various headers including `Accept-Language`, `User-Agent`, and `Accept-Encoding`. The response is an HTML document with the following content:

```

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Sun, 28 Jun 2026 04:54:54 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Server-Timing: total;dur=0.0607151
8 X-Content-Type-Options: nosniff
9 Referrer-Policy: strict-origin-when-cross-origin
10 Permissions-Policy: camera=(), microphone=(), geolocation=()
11 X-Frame-Options: SAMEORIGIN
12 Content-Length: 233724
13
14 <!DOCTYPE html>
15 <html>
16 <head>
17   <meta charset="utf-8" />
18   <meta name="robots" content="noindex,nofollow">
19   <meta http-equiv="x-ua-compatible" content="ie=edge" />
20   <title>
21     MAIN API Documentation
22   </title>
23   <link rel="preconnect" href="https://fonts.googleapis.com">
24   <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
25   <link href="https://fonts.googleapis.com/css2?family=JetBrains+Mono:wght@200;300;400;500" />

```

The interface also shows a 'Send' button, a 'Burp AI' button, and a 'Inspector' panel on the right with tabs for Request attributes, Request query parameter, Request body parameter, Request cookies, Request headers, and Response headers.

Broken Object Level Authorization (BOLA, OWASP API11)

BOLA tests whether one user can read another user's objects just by knowing the object ID. This is the highest-value test for a multi-tenant design tool. Penpot's IDs proved to be sequential

(both test files shared the 6b47f6d2-d354-81ba-8008 prefix with only the tail differing), which would make guessing neighbouring objects easy if access were not properly scoped, so this was tested thoroughly.

As userA, the request GET /api/main/methods/get-file?id=<userA-file-id> was captured and confirmed to return userA's own file (200, real file JSON). The id was then swapped to userB's file ID with userA's session cookie left unchanged, and resent. The server returned a 404 object-not-found rather than the file. The same swap was repeated on get-team-members with userB's team ID, which also returned a 404 object-not-found.

The control held across both object types. Notably, Penpot returns 404 object-not-found rather than 403 not-authorized, which is good design: from userA's perspective, userB's objects simply do not exist, so the API does not even leak that the object exists. The backend scopes queries to the caller's own teams.

Method	OWASP	Test	Input	Expected	Actual	Verdict
get-file	API1	userA reads userB's file by ID	userB file-id + userA cookie	denied	404 object-not-found	Not vulnerable
get-team-members	API1	userA reads userB's team members	userB team-id + userA cookie	denied	404 object-not-found	Not vulnerable

Request	Response
<pre> 1 GET /api/main/methods/get-file?id=6b47f6d2-d354-81ba-8008-3e5d363fae98& features=fdata/path-data&features=plugins/runtime&features= design-tokens/v1&features=variants/v1&features=layout/grid&features= styles/v2&features=fdata/objects-map&features=tokens/numeric-input& features=components/v2&features=fdata/shape-data-type HTTP/1.1 2 Host: 192.168.56.102:9001 3 Accept-Language: en-US,en;q=0.9 4 x-frontend-version: 2.16.1 5 x-external-session-id: null 6 x-event-origin: null 7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 8 accept: application/transit+json,text/event-stream,*/* 9 x-session-id: 371fd058-449b-80d2-8008-3f0a1dd84fec 10 x-client: penpot-frontend/2.16.1 11 Accept-Encoding: gzip, deflate, br 12 Cookie: auth-token= eyJhbGciOiJIc2E1Iiwia2lkIjoxLCJ2ZXIiOiJF9. ReacrZe7 kXSzilhRBMlbuazrmYBU2dC_v2miJzYK1BL0yLkWXFWNA. V3W88XjDN4qaL2Uh. 6CwPPquw0Nx LEfaN7xHALLyrGGwfyrslh7H66i4zt71vMCFVMSzdo0YF089KMIteB6DSBdw3x9kVoViEXcanJ bFW19gzkdUR05HB0fBmvV20jgcKKPcLnv0PafvzDVXdxMm8Ut20xIxx0ePV78KpHZ6kSP-Iv9S rTp1zLT53gitV0kd07GP0j2ZRKLKux4nhY2f03F7mAgC02YVkt0UzQzxZwy6_sHuFb0q8aA.kz q25eVzWCLnPLPE0LIJYA 13 Cache-Control: no-cache 14 Connection: keep-alive 15 16 </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: nginx 3 Date: Sun, 28 Jun 2026 16:39:36 GMT 4 Content-Type: application/transit+js 5 Connection: keep-alive 6 Vary: Accept-Encoding 7 etag: W/"QTAC6NTtzWTgyRFIz7tr5GLCJHP 8 Server-Timing: total;dur=0.06146019 9 X-Content-Type-Options: nosniff 10 Referrer-Policy: strict-origin-when- 11 Permissions-Policy: camera=(), micro 12 X-Frame-Options: SAMEORIGIN 13 Content-Length: 6186 14 15 ["A ", "~:features", ["~#set", ["fdata/path-data", "plugins/runtime", "design-tokens/v1", "variants/v1", "layout/grid", "styles/v2", "fdata/objects-map", </pre>

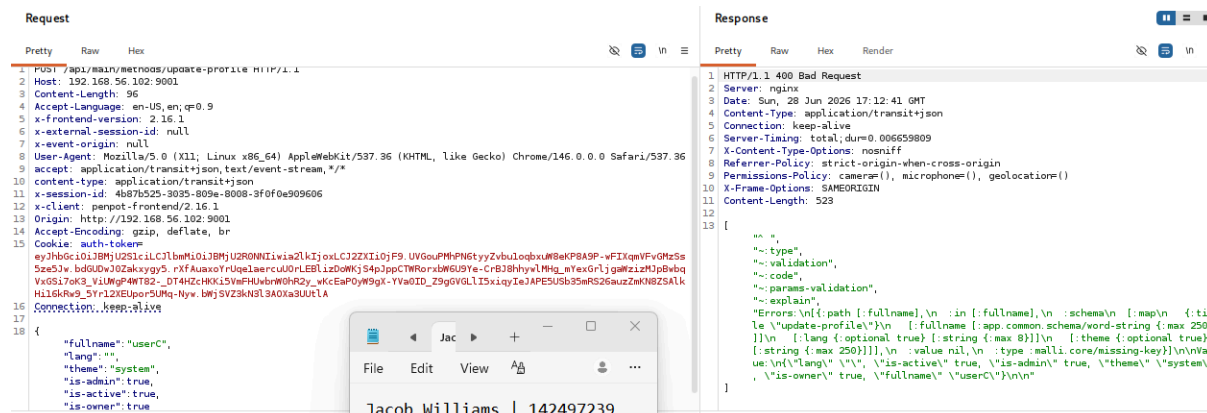
BFLA tests whether a low-privilege user can call privileged functions. As userC, a Viewer in TeamA, an attempt was made to self-promote to admin by calling POST /api/main/methods/update-team-member-role with userC's member ID and role:admin, using

Mass assignment tests whether privileges can be escalated by injecting fields into an update call that the caller should not control. This was run as userC (a Viewer) rather than userA, because userA is already an owner with is-admin true, so injecting is-admin on userA would

prove nothing. As userC, POST /api/main/methods/update-profile was sent with the normal fields plus injected is-admin:true, is-active:true, and is-owner:true.

The server rejected the whole request with a params-validation error. The explain output showed update-profile uses a closed schema permitting only fullname, lang, and theme, so the unexpected keys caused the request to be refused outright rather than accepted and ignored. The control held. A Viewer cannot smuggle privilege fields through update-profile. This is a different defense layer than the BFLA test: 3.3 was rejected at the authorization layer and at the schema-validation layer, and both held.

Method	OWASP	Test	Input	Expected	Actual	Verdict
update-profile	API3	Viewer injects is-admin/is-owner	extra privilege fields as userC	rejected/ignored	400 params-validation, closed schema	Not vulnerable



Authentication Testing (OWASP API2)

Token revocation: An access token was created and confirmed working via curl -H "Authorization: Token <token>" .../get-profile, which returned the profile. The token was revoked in the UI, and the same request was replayed. It no longer returned the account, instead returning an anonymous profile (all-zero UUID, "Anonymous User"). The token is rejected server-side after revocation. Control held. Returning 200-anonymous instead of 401 is a minor API design quirk, but it is not a vulnerability since no account data leaks.

Session invalidation on logout (FINDING): An authenticated get-profile request including the auth-token session cookie was captured and confirmed to return userB's full profile. Logout was then performed through the application logout button, with the browser confirmed on the login screen, and the identical request replayed with the same cookie. The server still returned

userB's full profile (email, fullname, is-active). The session was not invalidated server-side. Logout only clears the cookie in the browser, while the auth-token remains valid on the server. This is a confirmed vulnerability (detailed in the Bug Report).

Method	OWASP	Test	Input	Expected	Actual	Verdict
get-profile (token)	API2	Revoked token reused	replay after revoke	rejected	200 anonymous profile, no data	Not vulnerable
get-profile (session)	API2 / CWE-613	Session reused after logout	stale cookie post-logout	rejected	200, full profile returned	VULNERABLE

```

(kali@kali) ~$ curl -i -H "Authorization: Token eyJhbGciOiJIbmJ1ZS1lcjE3bmMiOiJBMjU2R0NNIn0.XxVxqApne26M2-C90SMEvORISctdi-RIXTYM1uhKqgbdv75hyNT7ow.BuflQv5pAdh6NtBP.-J1I
21BseIG2WmndunxrzlwQmz6_Sot0Fwnc5x3vDLYuk-hMMpc0yVvvsI0kNg7GKIlLmA_lBIEY8MrnLV1Qu61167jb_4QqICq3UDMDuZlthyRXdjymQn1r7hoYkujlxZInoRZXixT2078j7TWDY1-RQ8I_y46c
aDIBEO3dfP0-cCho-6iN6Nift3JexLzkOpJM02pVBtq.1dqFHFJaA3QpAw7uZU0dQ" http://192.168.56.102:9001/api/main/methods/get-profile
HTTP/1.1 200 OK
Server: nginx
Date: Sun, 28 Jun 2026 17:23:36 GMT
Content-Type: application/transit+json
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Server-Timing: total;dur=0.007988064
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
X-Frame-Options: SAMEORIGIN

[{"^","~:email","jacob07will@gmail.com","~:is-demo",false,"~:auth-backend","penpot","~:fullname","userC","~:modified-at","-m1782665612898","~:theme","system",
,"~:lang","","~:is-active",true,"~:default-project-id","~:u0a196bb0-93db-81b5-8008-3f0dbc99838e","~:id","~:u0a196bb0-93db-81b5-8008-3f0dbc986fcb","~:is-muted",
false,"~:default-team-id","~:u0a196bb0-93db-81b5-8008-3f0dbc995c79","~:created-at","-m1782665612898","~:is-blocked",false,"~:props":[{"^","~:nudge":[{"^","~:small",1},{"^","~:big",10,"~:small",1}],{"~:v2-info-shown",true,"~:viewed-tutorial?",false,"~:workspace-visited",true,"~:viewed-walkthrough?",false,"~:onboarding-questions":[{"^",
,"~:role","student-teacher","~:start-with","prototyping","~:expected-use","education","~:experience-design-tool","canva"],"~:release-notes-viewed","2.16","~:
onboarding-questions-answered",true}]]

(kali@kali) ~$ curl -i -H "Authorization: Token eyJhbGciOiJIbmJ1ZS1lcjE3bmMiOiJBMjU2R0NNIn0.XxVxqApne26M2-C90SMEvORISctdi-RIXTYM1uhKqgbdv75hyNT7ow.BuflQv5pAdh6NtBP.-J1I
21BseIG2WmndunxrzlwQmz6_Sot0Fwnc5x3vDLYuk-hMMpc0yVvvsI0kNg7GKIlLmA_lBIEY8MrnLV1Qu61167jb_4QqICq3UDMDuZlthyRXdjymQn1r7hoYkujlxZInoRZXixT2078j7TWDY1-RQ8I_y46c
aDIBEO3dfP0-cCho-6iN6Nift3JexLzkOpJM02pVBtq.1dqFHFJaA3QpAw7uZU0dQ" http://192.168.56.102:9001/api/main/methods/get-profile
HTTP/1.1 200 OK
Server: nginx
Date: Sun, 28 Jun 2026 17:23:58 GMT
Content-Type: application/transit+json
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Server-Timing: total;dur=0.020937035
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
X-Frame-Options: SAMEORIGIN

[{"^","~:id","~:u00000000-0000-0000-0000-000000000000","~:fullname","Anonymous User"]

```

Request

Pretty Raw Hex

1 GET /api/main/methods/get-profile HTTP/1.1
2 Host: 192.168.56.102:9001
3 Accept-Language: en-US,en;q=0.9
4 x-frontend-version: 2.16.1
5 x-external-session-id: null
6 x-event-origin: null
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 accept: application/transit+json,text/event-stream,*/*
9 x-session-id: 120488c6-8db8-80e5-8008-3f1702fd863e
10 x-client: penpot-frontend/2.16.1
11 Accept-Encoding: gzip, deflate, br
12 Cookie: auth-token=eyJhbGciOiJIc2UiLCJlbmMiOiJBMjU2R0NNIiwia2kiOiJ0xL3J2ZXIiOiJF9. ZjPe409Jl3w7HuiKcn9BoMmWdnFZKz0Hkeogvxc-wj3hoCgcg-hUrQ. 5Md6ccHUVmokitIqU. 87yMe4z92-6c0Enx5go89UsWP8e5RrA1pKi07F rMeSGegqALfJHc4KR6gHKo6HNDhZ0jftwSVNADws2AS44yOACJDPKFJmGGy9on2uelhBzgySU02Rgr05ApnxOgWdMnIGsLKICITCyjF0mKF_Sx3ocRJGWILbYp eto25i8bjb072sqUqRw3n3PAyJ2gc0LTatZ7VTvCbWQ4YW-5FrLoZmc_mvC0eqrmTA00pQ. 3Ed5scxSyP3BA7bK0nbxcw
13 Connection: keep-alive
14
15

Response

Pretty Raw Hex Render

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Sun, 28 Jun 2026 17:34:11 GMT
4 Content-Type: application/transit+json
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Server-Timing: total;dur=0.026515486
8 X-Content-Type-Options: nosniff
9 Referrer-Policy: strict-origin-when-cross-o
10 Permissions-Policy: camera=(), microphone=(
11 X-Frame-Options: SAMEORIGIN
12 Content-Length: 885
13
14 [
15 {
16 "email",
17 "jwilliams125@myseneca.ca",
18 "is-demo",
19 false,
20 "auth-backend",
21 "penpot",
22 "fullname",
23 "userB",
24 "modified-at",
25 "m1782619175596",
26 "is-active",
27 true,
28 }
29]

Penpot | Full-stack design

PortSwigger

Not secure 192.168.56.102:9001/#/auth/login

Burp

Project Intruder Repeater View Help

Burp Suite Professional V2026.4.3 - Temporary Project - Educational License

Dashboard Target Proxy Intruder Collaborator Sequencer Decoder Comparer Logger Organizer

Extensions Discover

1 8 9 +

Send Cancel

Burp AI

Target: http://192.168.56.102:9001 HTTP/1.1

Request

Pretty Raw Hex

1 GET /api/main/methods/get-profile HTTP/1.1
2 Host: 192.168.56.102:9001
3 Accept-Language: en-US,en;q=0.9
4 x-frontend-version: 2.16.1
5 x-external-session-id: null
6 x-event-origin: null
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 accept: application/transit+json,text/event-stream,*/*
9 x-session-id: 120488c6-8db8-80e5-8008-3f1702fd863e
10 x-client: penpot-frontend/2.16.1
11 Accept-Encoding: gzip, deflate, br
12 Cookie: auth-token=eyJhbGciOiJIc2UiLCJlbmMiOiJBMjU2R0NNIiwia2kiOiJ0xL3J2ZXIiOiJF9. ZjPe409Jl3w7HuiKcn9BoMmWdnFZKz0Hkeogvxc-wj3hoCgcg-hUrQ. 5Md6ccHUVmokitIqU. 87yMe4z92-6c0Enx5go89UsWP8e5RrA1pKi07F rMeSGegqALfJHc4KR6gHKo6HNDhZ0jftwSVNADws2AS44yOACJDPKFJmGGy9on2uelhBzgySU02Rgr05ApnxOgWdMnIGsLKICITCyjF0mKF_Sx3ocRJGWILbYp eto25i8bjb072sqUqRw3n3PAyJ2gc0LTatZ7VTvCbWQ4YW-5FrLoZmc_mvC0eqrmTA00pQ. 3Ed5scxSyP3BA7bK0nbxcw
13 Connection: keep-alive
14
15

Response

Pretty Raw Hex Render

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Sun, 28 Jun 2026 17:37:22 GMT
4 Content-Type: application/transit+json
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Server-Timing: total;dur=0.11094968
8 X-Content-Type-Options: nosniff
9 Referrer-Policy: strict-origin-when-cross-origin
10 Permissions-Policy: camera=(), microphone=(), geolocation=()
11 X-Frame-Options: SAMEORIGIN
12 Content-Length: 885
13
14 [
15 {
16 "email",
17 "jwilliams125@myseneca.ca",
18 "is-demo",
19 false,
20 "auth-backend",
21 "penpot",
22 "fullname",
23 "userB",
24 "modified-at",
25 "m1782619175596",
26 "is-active",
27 true,
28 }
29]

Log into my account

Penpot is the free open-source design tool for Design and Code collaboration

WORK EMAIL

Work email

PASSWORD

Password

Forgot password?

CONTINUE

Jac

File Edit View

Jacob Williams | 142497239

Rate Limiting and Resource Consumption (OWASP API4)

This test also satisfies the fuzzing requirement. login-with-password was sent to Turbo Intruder, the password marked as the payload, concurrentConnections set to 10, and 500 wrong-password attempts run against a single valid account. All 500 returned 400 wrong credentials at a fast, steady rate with no 429, no slowdown to a stop, no account lockout, and no CAPTCHA. The run completed all 500 in seconds.

This is a confirmed finding. The login endpoint enforces no rate limiting or lockout, so an attacker can brute-force passwords and credential-stuff at high speed against any known

Threat Modelling and Vulnerability Alignment

This section shows that the Lab 3 and Lab 4 test cases trace back to the Lab 2 threat modelling and to the known vulnerabilities from prior labs.

Threat Modelling Outcomes (Lab 2)

Each covered STRIDE or PASTA threat is mapped below to the test case that addresses it and how that test case validates or mitigates it.

Threat	STRIDE	Test case	How it validates or mitigates	Result
Session cookie replay	Spoofing	3.5 Session invalidation	Stale cookie replayed after logout still returned the profile	VULNERABLE (CWE-613)
Personal access token abuse	Spoofing	3.5 Token revocation	Revoked token replayed and rejected server-side	Control held
Account takeover via invite token	Spoofing, EoP	Invite token replay, prepare-register test	Reproduction attempt validates CVE-2026-44986 patch	Patch verified
Unauthorized file access or edit	Tampering, Info Disc	3.2 BOLA	Cross-user read returned 404 object-not-found	Control held
Viewer or Editor privilege escalation	EoP	3.3 BFLA, 3.4 Mass assignment	Role change denied at authz layer; injected admin fields rejected by closed schema	Control held
Server-side file read via fonts	Info Disc, Tampering	create-font-variant path traversal	Validates CVE-2026-26202 patch	Patch verified
Method inventory exposure	Info Disc	3.1 Doc exposure	Doc endpoint served the full method list unauthenticated when enabled	Informational (default off)

Verbose error leakage	Info Disc	3.4, 3.5 error handling	400 responses leaked mali schema detail	Informational (CWE-209)
Login brute force	DoS, Spoofing	3.6 Rate limiting	500 rapid attempts, no 429, no lockout	VULNERABLE (CWE-307)
MCP RCE	EoP	Nmap port 4403 check	Confirms MCP service is not deployed	Verification only
Missing headers and transport	Info Disc	Cookie flag and header audit	Confirms missing CSP and HSTS at nginx	Deployment-level

The two live findings, 3.5 and 3.6, are the strongest validations. Session invalidation confirms the session-replay threat and carries a repudiation implication, and the rate-limiting gap confirms both the brute-force enabler and the resource-consumption dimension of DoS.

Deprioritized threats

Threat group	Why deprioritized and less critical	Future testing
SSO, OIDC, LDAP spoofing	Not enabled in the deployment, so no attack surface; less critical than findings that apply to the default config	Stand up OIDC and LDAP, test email-claim trust and role mapping
Database, storage, config attacks	Assume infrastructure access outside the authenticated-user model; destructive testing was out of scope	Cover in Lab 5 hardening: secrets, network isolation, least privilege
Repudiation	Logging and attribution are configuration concerns, not exploitable code flaws	Enable audit logging, verify token use is recorded with IP and timestamp
Denial of Service	Load testing is excluded to protect shared lab infrastructure	Controlled load tests on an isolated instance
MCP active exploitation	Optional module not installed; related CVE patched before the tested version	Enable MCP in isolation to validate the patched /execute endpoint
Webhook and websocket tampering	Not configured and outside the API scope of this section	Configure webhooks, test payload exposure, replay, and attribution

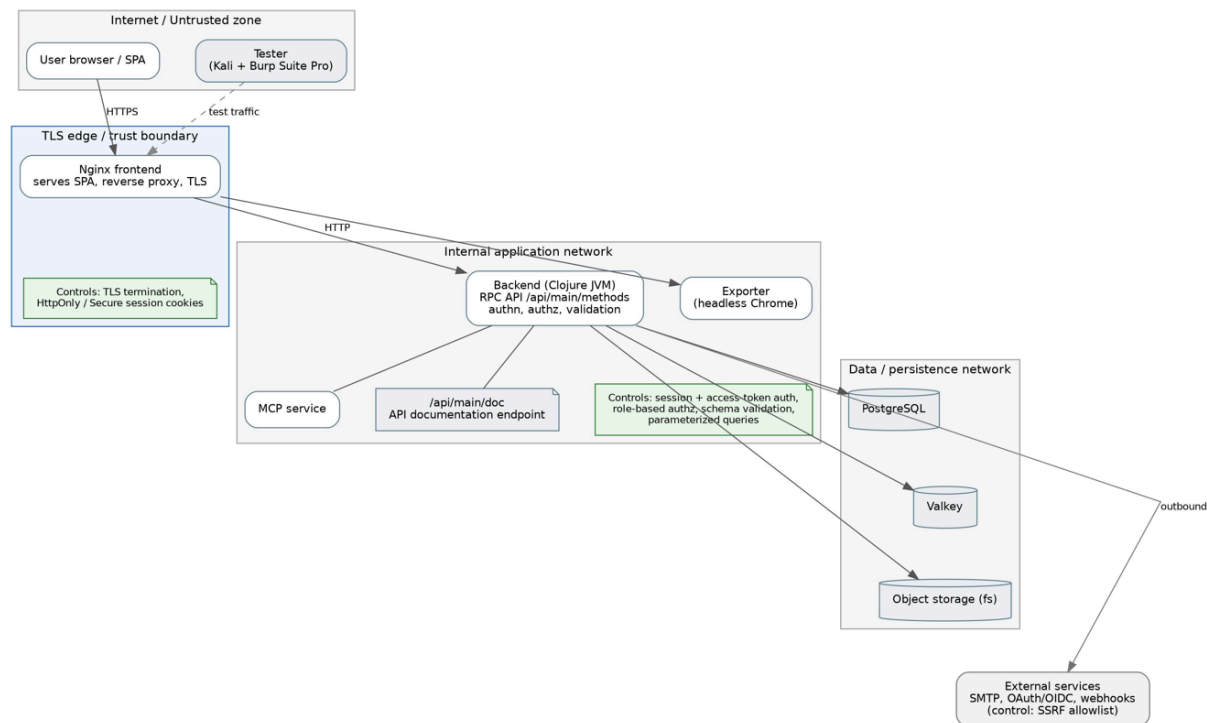
Known Vulnerabilities (Lab 1 and prior versions)

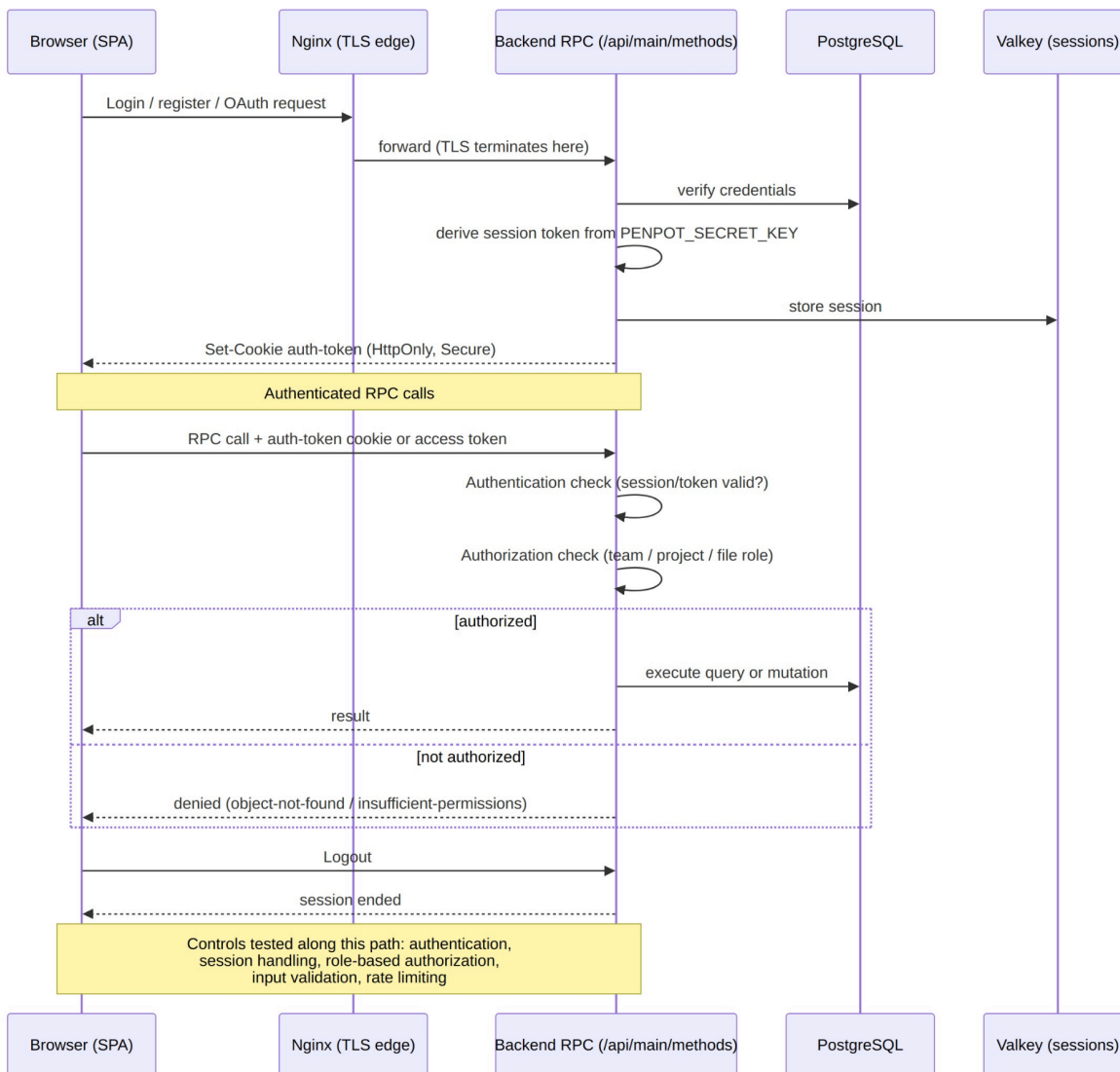
Lab 1 assessed BookStack, so its findings are treated as general vulnerability classes. Penpot's own previous-version advisories and competitor incidents are included to cover the selected application and its competitors. All map to a test case below.

Vulnerability	Source	Related test case	Result
SSRF via backend URL fetch	Lab 1 BookStack (wkhtmltopdf history)	create-file-media-object-from-url SSRF test	Patched (Penpot 2.15.0), not reproducible
SQL injection	Lab 1 BookStack (Eloquent ORM)	Injection testing, ZAP active scan	Not identified
XSS via rich content	Lab 1 BookStack (HTML Purifier, TinyMCE)	Manual input validation on text fields	Input handling held
Weak cookie and transport	Lab 1 BookStack (Secure Cookies, CSP)	Cookie flag and header audit	Missing CSP and HSTS, deployment-level
Arbitrary file read, create-font-variant	Penpot prior version, CVE-2026-26202	Path traversal test	Patch verified
Account takeover, invite flow	Penpot prior version, CVE-2026-44986	Invite token replay test	Patch verified
Authenticated SSRF, image import	Penpot prior version, CVE-2026-45806	SSRF test	Patch verified
MCP unauthenticated /execute	Penpot prior version, CVE-2026-45805	Nmap port 4403 check	Service not deployed
React2Shell RCE	Dependency analysis, CVE-2025-55182	OWASP Dependency-Check	Not exploitable (no React Server Components)
Command injection, Figma MCP	Competitor, Figma, CVE-2025-53967	Informed MCP verification rationale	Comparison only, MCP not deployed
Account breach, hardening	Competitor, Canva, 2019 breach	Informed session and cookie-flag focus	Session weakness found, transport noted

Every known vulnerability maps to a test case. The Penpot advisories were all patched before the deployed version, so those test cases served as patch verification. The one class that produced a live finding on the current version was authentication and session handling, confirmed in Section 3.5 and the Bug Report.

Security Architecture & Diagrams





Security Unit Testing & Automation

Areas suitable for automated security testing

Penpot's backend is well suited to automated testing because its security-relevant logic is concentrated in a few clear layers rather than scattered through the UI. Three areas stand out. The first is the RPC command layer, where every incoming request is validated against a declared schema before any handler runs, which makes input validation straightforward to test in isolation. The second is the token subsystem, which issues and verifies the encrypted tokens used for sessions, invitations, and password recovery, and which can be tested as a self-contained generate-and-verify cycle. The third is the permission layer, where team roles of owner, admin, editor, and viewer are translated into concrete capability flags, giving a small, deterministic surface for role-based access checks. Password hashing and error handling are secondary candidates, since both are pure functions with predictable inputs and outputs.

Proposed Basic Unit Tests

For input validation, the tests submit malformed parameters to a representative command such as login and confirm that each is rejected with a validation error rather than being processed or causing a server fault. Cases include missing required fields, a malformed email address, a value of the wrong type, and an oversized field intended to probe for a denial-of-service path. The expected result in every case is a controlled rejection.

For token verification, the tests cover the full lifecycle of an encrypted token. A freshly issued token should decode and return its original claims, an expired token should be refused, a token presented with the wrong issuer should be refused, a token forged under a different secret should fail to decrypt, and a structurally altered token should fail verification. Together these confirm that the token layer enforces both integrity and validity rather than merely parsing whatever it is given.

For role-based access enforcement, the tests assert that each role resolves to the correct set of capabilities: an owner receives ownership, administrative rights, and edit access; an admin receives administrative and edit rights but not ownership; an editor receives edit access only; and a viewer receives read access alone. A final case confirms that an unrecognised role is refused outright rather than being granted any default capability, which guards against privilege escalation through an unexpected role value.

The .clj and .py files I produced earlier already implement these exact cases if you want working code to reference, but the descriptions above are enough for the write-up itself